

Warsaw, October 10, 2024

Decision

DKN.5131.35.2021

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572), hereinafter referred to as "KPA", Article 7 sections 1 and 2, Article 60, Article 101, Article 102 section 1 point 1 and section 3, Article 103 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as "u.o.d.o.", as well as Article 57 section 1 letters a) and h), Article 58 section 2 letter i), Article 83 sections 1 - 3, Article 83 section 4 letter a) in connection with Article 24 section 1, Article 25 section 1, Article 28 sections 1 and 3, and Article 32 sections 1 and 2, as well as Article 83 section 5 letter a) in connection with Article 5 section 1 letter f) and Article 5 section 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 on the protection of individuals with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as "Regulation 2016/679", after conducting an ex officio administrative procedure regarding the violation of personal data protection regulations by X in K. (ul. (...), (...) K.), Y in K. (ul. (...), (...) K.), as well as Z sp. z o.o. based in Ł. (ul. (...), (...) Ł.), the President of the Personal Data Protection Office:

1) stating the violation by X in K. (ul. (...), (...) K.):

a) of the provisions of Article 24 section 1, Article 25 section 1, and Article 32 sections 1 and 2 of Regulation 2016/679, consisting of the failure to implement appropriate technical and organizational measures ensuring a level of security appropriate to the risk of data processing using portable storage devices, which measures would have prevented the employee of Z sp. z o.o. based in Ł. (ul. (...), (...) Ł.) from recording personal data on an unsecured data carrier and consequently would have allowed avoiding a violation of personal data protection, resulting in a breach of the principle of confidentiality due to the loss of this carrier (Article 5 section 1 letter f) of Regulation 2016/679) and the principle of accountability (Article 5 section 2 of Regulation 2016/679);

b) of the provision of Article 28 section 1 of Regulation 2016/679, consisting of the lack of verification of the data processor to determine whether it provides sufficient guarantees for the implementation of appropriate technical and organizational measures, so that the processing meets the requirements of Regulation 2016/679 and protects the rights of data subjects, imposes on X in K. (ul. (...), (...) K.), for the violation of Article 5 section 1 letter f), Article 5 section 2, Article 25 section 1, Article 28 section 1, and Article 32 sections 1 and 2 of Regulation 2016/679, an administrative fine in the amount of 15,000 PLN (in words: fifteen thousand zlotys);

2) stating the violation by Y in K. (ul. (...), (...) K.):

a) of the provisions of Article 24 section 1, Article 25 section 1, and Article 32 sections 1 and 2 of Regulation 2016/679, consisting of the failure to implement appropriate technical and organizational measures ensuring a level of security appropriate to the risk of data processing using portable storage devices, which measures would have prevented the employee of Z sp. z o.o. based in Ł. (ul. (...), (...) Ł.) from recording personal data on an unsecured data carrier and consequently would have allowed avoiding a violation of personal data protection, resulting in a breach of the principle of confidentiality due to the loss of this carrier (Article 5 section 1 letter f) of Regulation 2016/679) and the principle of accountability (Article 5 section 2 of Regulation 2016/679);

b) of the provisions of Article 28 sections 1 and 3 of Regulation 2016/679, consisting of the lack of verification of the data processor to determine whether it provides sufficient guarantees for the implementation of appropriate technical and organizational measures, so that the processing meets the requirements of Regulation 2016/679 and protects the rights of data subjects, as well as the entrustment of personal data processing to Z sp. z o.o. based in Ł. (ul. (...), (...) Ł.), based on an agreement that did not contain all the elements required under Article 28 section 3 of Regulation 2016/679, imposes on Y in K. (ul. (...), (...) K.), for the violation of Article 5 section 1 letter f), Article 5 section 2, Article 25 section 1, Article 28 sections 1 and 3, and Article 32 sections 1 and 2 of

Regulation 2016/679, an administrative fine in the amount of 20,000 PLN (in words: twenty thousand zlotys);

3) stating the violation by Z sp. z o.o. based in Ł. (ul. (...), (...) Ł.) of the provisions of Article 32 sections 1 and 2, as well as Article 32 sections 1 and 2 in connection with Article 28 section 3 letters c) and f) of Regulation 2016/679, consisting of the failure to implement appropriate technical and organizational measures ensuring the security of personal data, including ensuring their confidentiality, imposes on Z sp. z o.o. based in Ł. (ul. (...), (...) Ł.), an administrative fine in the amount of 24,882.21 PLN (in words: twenty-four thousand eight hundred eighty-two zlotys and twenty-one groszy).

JUSTIFICATION

On February 5, 2021, a notification of a personal data breach was submitted to the President of the Personal Data Protection Office by Y in K. (ul. (...), (...) K.), hereinafter referred to as "Y", registered under reference number (...). This breach – according to the content of the notification – consisted of the loss by an employee of Z sp. z o.o. based in Ł. (ul. (...), (...) Ł.), hereinafter also referred to as the "Data Processor" or "Company", of a data carrier type USB flash drive (hereinafter: "USB Flash Drive"), containing personal data of approximately one thousand... former and current employees and collaborators Y (hereinafter referred to as "Data Subjects Y"). The data of these individuals located on the Pendrive included (according to the content of section 6 of the application form) their: first names, surnames, parents' names, dates of birth, bank account numbers, residential or temporary addresses, PESEL identification numbers, email addresses, salary and/or asset information, mother's maiden names, series and numbers of identity cards, and phone numbers (these data are hereinafter referred to as "Data Y").

Also, on February 5, 2021, X in K. (ul. (...), (...) K.), hereinafter referred to as "X", made a preliminary notification of a personal data breach concerning the same incident. This notification was received by the local Office on February 10, 2021, and was registered under reference number (...). Supplementary notifications were sent by X on March 8 and August 31, 2021, with the latter indicating that the Pendrive lost by an employee of the Data Processing Entity contained personal data of five hundred forty-nine individuals (employees, retirees, and former employees, contractors, and participants in intervention work), hereinafter referred to as "Data Subjects X", which varied in scope for each group of subjects and belonged to the following categories: first names, surnames, parents' names, date of birth, bank account number, residential or temporary address, PESEL identification number, salary and/or asset information, mother's maiden name, series and number of identity card, phone number, health-related data (data regarding the absence of contraindications for employment, data contained in occupational health assessments), as well as other data: place of birth, nationality, timekeeping data (including, among others, data on vacations, medical leave), information on health and safety training, method of payment (bank name), information on remuneration, data regarding completed schools, employment history (data contained in employment certificates), names and surnames of children and their dates of birth. Additionally, from X's letter dated September 24, 2021, it follows that among this data were also tax identification numbers (NIP) and data contained in disability certificates. This data concerned individuals employed at X from 1990 to 2021 (as indicated in X's letter dated September 28, 2022) and will hereinafter be referred to as "Data X".

Both administrators, in response to the received requests from the President of the Personal Data Protection Office (sent to Y on February 9, 2021, and to X on August 2, 2021), notified, based on Article 34 of Regulation 2016/679, the individuals whose data was on the aforementioned Pendrive about the occurrence of a personal data breach. The President of the Personal Data Protection Office, hereinafter also referred to as "President of UODO" or "supervisory authority", conducted an explanatory procedure regarding the reported breaches concerning the same incident (registered under reference numbers: (...) and (...)), and subsequently initiated ex officio administrative proceedings on August 5, 2021 (reference number: DKN.5131.35.2021) regarding the possibility of a breach by X, Y (as data administrators), as well as by Z sp. z o.o. based in Ł. (as the data processor), of the obligations arising from Article 5(1)(f), Article 5(2), Article 24(1), Article 25(1), Article 32(1) and (2), as well as Article 28(1) and (3) of Regulation 2016/679 – in connection with breaches of personal

data protection of Data Subjects X and Y.

The President of UODO, as a result of the conducted explanatory procedure regarding the reported personal data breach and the administrative proceedings, established the following factual state: X entered into an agreement on November 16, 2020, with Z sp. z o.o. based in Ł., the subject of which included, among other things, the transfer of data from the existing payroll system. On the same day, a "Contract (...)" was also concluded between these entities. The next contract (...) was concluded by these parties on December 29, 2020 (which specified, among other things, the scope of the entrusted data).

On December 29, 2020, Y also entered into a contract with Z sp. z o.o. based in Ł. regarding the same subject matter. The "Contract (...)" was signed between them on the same day. None of the above contracts contained provisions specifying the manner of providing the Data Processing Entity with the personal data to be transferred. They also did not specify any potential method of securing portable data carriers such as Pendrives.

On January 5, 2021, an employee of Z sp. z o.o. based in Ł. (hereinafter referred to as "Employee of the Data Processing Entity" or "Employee of the Company") went to X to make final adjustments to the payroll program that had been operational since December 15, 2020. Since the Data Processing Entity did not have permission for remote connection with X, the Employee of the Data Processing Entity asked one of X's employees to "transfer" the database in the format (...) so that remote assistance could be provided to the employees of this administrator. The employee of X provided this database in the specified format (as a single file) on the company Pendrive belonging to the Employee of the Company, which at the time of this transfer did not contain any other data. During this action, the Employee of X, who was also employed by Y (under a contract for specific work), additionally transferred to the Employee of the Data Processing Entity – during work at X and despite the prohibition of using the IT infrastructure at X for private purposes – the database concerning Data Subjects Y, which he downloaded by connecting through (...) to the Y system using a mobile phone. The actual uploading of Data Subjects Y's data took place with the help of the company computer of the Employee of X in the building of X. Due to the different stage at which the process was...

****Implementation of the New Payroll Program in Y, Data of Data Subjects Y****

The data of Data Subjects Y was placed in a format (...) – in one folder with a larger number of files. The Employee's USB drive of the Data Processor was not secured against unauthorized access to its contents – similarly to the files containing personal data of Data Subjects X and Y.

From point (...) of the procedure in force at the time of the breach at Z sp. z o.o. based in Ł., "Procedure (...)" indicates that when using portable drives, data must be deleted immediately after being copied to a permanent disk and verification of the correctness of the readout. This procedure did not then foresee the obligation to encrypt USB drives used for transporting digital documents (such an obligation was introduced only on March 1, 2021 – see point (...) of the procedure referred to in this justification), and the agreements made by the Company with X and Y, mentioned in points 1 and 2 above, did not specify (as already indicated above) the method of sharing the transferred data.

The Employee of the Data Processor, after returning from X, copied data from folder Y to the disk in the company laptop for the purpose of transferring data. The Employee of the Company, after using the personal data provided to him by the Employee of X – contrary to the obligation mentioned in point (...) of the procedure indicated in point 5 above – did not delete it from the USB drive. The Employee of the Data Processor did not look into the data contained in folder X, as this data was needed in case assistance was required for the employees of X.

On January 14, 2021, the USB drive fell out of the Employee of the Company's pocket while getting into a car in S. The fact of losing the data carrier was noticed by a third party (hereinafter referred to as the "Finder"), but he did not manage to draw his attention to it – the Employee drove away. The USB drive was then taken by the Finder, who posted an announcement about finding the USB drive on the website (...) the same day.

Since the Employee of the Data Processor did not respond to the aforementioned announcement (he did not notice the absence of the USB drive, as it was not needed at that time), the Finder decided to check what was on the found carrier – two folders appeared: Y K. and X K. He then contacted the secretary of X, who, not yet aware of the loss of the USB drive by the Employee of the Company and not knowing what data was contained in folder X K., asked the Finder to attempt to open it. The document in that folder was highlighted with a white icon, and the attempt to open it by the Finder was unsuccessful (the computer on which the Finder attempted to open the file, according to the Finder's statement, did not have the program enabling its opening) – the Finder was therefore suggested to contact Y, which concerned the second folder located on the USB drive (see: statement of the Finder from June 28, 2021, and the memo of the person who conducted the aforementioned phone conversation with the Finder).

Notified by the Finder, Y "(...) recognized the USB drive and determined that the data on the USB drive belonged to its employees (...)" (see: letter from X dated March 30, 2021). It then informed the Data Processor on February 3, 2021, that the lost USB drive had been found (see: content of the letter from the Data Processor to X dated February 4, 2021). On the same day, the Finder – according to his statement from February 3, 2021 – sent the USB drive to Y by courier.

In connection with the above, on February 4, 2021, the Data Processor provided X with the Finder's statement regarding the USB drive, in which he described the circumstances of his possession of the carrier and that he did not use, copy, transfer, or disclose to third parties the data contained on it (see: statement of the Finder from February 3, 2021).

On February 5, 2021, X and Y reported a personal data breach that occurred in connection with the loss of the data carrier. As indicated above, it was a business and unencrypted carrier. It was established that it contained two folders: one of them was named "Y K." and contained data of Data Subjects Y in the format (...) in several dozen files, while the other (named "X K.") contained data of Data Subjects X from 1990-2021 in the form of a single file: a database (...).

The courier shipment containing the USB drive arrived at Y on February 8, 2021. On the same day, it was opened and its contents checked in a commission – participants in these activities included, among others, the Director of X, the Director of Y, and the Employee of the Data Processor who lost the USB drive. As stated in the letter from the Company dated June 29, 2021: "The USB drive was opened by the Data Administrator of Y (...) on a company computer (...). He first opened folder Y. There were several dozen database files (...). With the help of Notepad, he opened one of those files. The files (...) after being opened in Notepad (...) appear as characters (...) interspersed from time to time with field values without field names. The field values are legible. In the file, he found names and surnames of individuals as well as values that could be considered dates of birth and PESEL numbers. He asked the Deputy Director of Y (...) to confirm the provided names. (...) The Director confirmed these names as employees of Y. He did not open other files. Then he moved to folder X. There was one file with the extension (...). It was a backup of the new database of system Z. The Data Administrator of Y opened this file with Notepad without looking at its contents as he was not authorized to view the X database." After the aforementioned verification of the contents of the carrier, it was formatted.

From the explanations of the Data Processor submitted in this case (in a letter received by the Office on April 9, 2021), it follows that reading data from X from the database (...) would require the use of tools from the company (...), while the databases (...) have their own structure, and the data is distributed across many files. These files can be opened with Notepad, and the data is visible scattered within the file among the characters.

w format (...) without field description.

The President of the UODO received explanations from X, from which the following findings arise (see: letters from X sent to the supervisory authority: March 8 and 30, June 28, August 12 and 31, and September 24, 2021, September 28, 2022, and also November 16, 2023):

1) X conducted a cyclical risk analysis related to the processing of personal data (which still takes place once a year), but prior to the occurrence of the data protection breach in question, no risk

analysis strictly related to the process of changing the payroll and personnel program was conducted, as X explained: "the scope of processed data remained the same, as did the data processing process in the program, and the decision to change was solely due to the fact that the previous program was insufficiently compatible with the computers and other programs used by X K. type '(...)'."

2) One of the attachments to the applicable policy in X (...) is the "Instruction (...)" (hereinafter referred to as "Instruction X"). According to the content of § (...), data is stored on portable media only when necessary, for the time required to fulfill the purpose for which it was recorded on the media, and after the storage period has expired, the contents of the media are subject to deletion using tools approved for use by X. It is prohibited to transfer unsecured confidential data outside the premises of X in K. (§ (...) Instruction X). However, the use of company electronic media (USB drives) that are secured against data loss through encryption is permitted (§ (...) Instruction X). According to the content of § (...) of the aforementioned Instruction, the use of IT infrastructure in X for private purposes is prohibited.

3) X indicated that prior to the occurrence of the data breach in question, as part of regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processed personal data, a risk analysis was conducted in accordance with Procedure (...) dated December 23, 2011. Currently, the IT Team of X conducts an analysis and review of the risks held within its organizational unit every year and certain changes have been made to Instruction X. Furthermore, immediately after the occurrence of the data breach in question, an additional cyclical risk analysis was conducted, and additional security measures were implemented (including training all employees processing personal data). X did not indicate any other actions taken in the framework of fulfilling the obligations under Article 32(1)(d) of Regulation 2016/679.

4) When asked how he verified whether the data processor provides sufficient guarantees for the implementation of appropriate technical and organizational measures so that the data processing meets the requirements of Regulation 2016/679, in accordance with Article 28(1) of that regulation, X explained that he has been cooperating with the Company for about 30 years and that the previous cooperation had been successful and exemplary. He also explained that the Data Processor indicated security measures in the appropriate attachment to the contract before signing it, which solutions were accepted by X. He also noted that "only after fulfilling these solutions was the contract signed." The Administrator verified the level of security of personal data with the processor each time he signed a contract with that entity and the fulfillment of obligations arising from Regulation 2016/679.

5) The "Contract (...)" concluded between X and the Data Processor on November 16, 2020, contained the obligation of the Data Processor to secure the entrusted personal data during processing by implementing appropriate technical and organizational measures ensuring an adequate level of security corresponding to the risk associated with the processing of personal data referred to in Article 32 of Regulation 2016/679 (§ (...)). This contract also specified the scope of entrusted data, which was to include basic personal data (in particular: first name, last name, phone number, electronic identification data) concerning X's employees and contractors of this Administrator in the scope of executing commercial contracts. On December 29, 2020, X concluded a "Contract (...)" with the Data Processor, in which § (...) specified the scope of entrusted personal data to include: personnel data (including basic personal data, i.e., first name and last name, phone number, electronic identification data, documentation describing the course of employment, certificates, documentation confirming qualifications and professional skills, medical certificates, ZUS insurance registrations, and other personal files concerning employed workers, job candidates, and individuals undergoing vocational training with this Administrator), as well as payroll data (including data on employee remuneration, named payroll cards, payroll lists, settlement documentation with ZUS, income cards for tax purposes, information on medical leave) and other data constituting payroll documentation of employees employed by X. In § (...) of this contract, the Data Processor declared that it applies security measures that meet the requirements of Regulation 2016/679, which were listed in Annex No. (...) to this contract. This annex provided, for example, certain principles regarding archival data carriers (which are to be "appropriately secured"), and also indicated that remote access to data is carried out only via encrypted communication channels ((...)). In the analyzed factual state, the USB drive was not an archival data carrier, as the Data of X was made available to the Company in case

assistance was needed for X's employees. It should also be noted again that according to the explanations of the Data Processor (see: inter alia, the letter from the Company dated February 19, 2024), on January 5, 2021, it did not have

on the consent for remote connection with X. In light of the above, it should be recognized that the security measures specified in Annex 1 do not contain provisions that are significant from the perspective of the analyzed violation of personal data protection. 6) Following the occurrence of the data protection breach, X made changes to the content of the agreement (...) – including the introduction of a principle according to which the Data Processor is liable for damages caused by its actions related to the failure to fulfill the obligations imposed directly on the data processor by Regulation 2016/679 or when it acted outside the lawful instructions of the Administrator or contrary to those instructions. The Data Processor is also to be liable for: “damages caused by the application or non-application of appropriate security measures.” Contractual penalties related to the disclosure or use of personal data contrary to the agreement were also introduced. In connection with the agreement concluded with the Company, a new method of encrypted connection using a “secure link” was provided. Employees responsible for preparing data processing agreements were instructed on the necessity to “increase and intensify” the verifications conducted within the signed agreements. Actions were also taken to implement changes in the organizational structure of the department involving a change in the scope of duties of employees (so that the main administrator would be the direct supervisor of the IT team members, which is intended to ensure the administrator's control over them). Additional training for employees was also initiated. 7) X conducted an inspection of the Data Processor on March 5, 2021, based on which recommendations were directed to the Company on May 12, 2021 (including those regarding retraining employees in the area of encrypting personal data in the case of data shared on storage devices and the necessity of immediate deletion of data from storage devices). Before the occurrence of the personal data breach, X did not conduct inspections or audits in the Company related to the processing of personal data by this Company. 8) X identified a breach by its employee, who disclosed the data of Data Subjects X and Y, established organization and work order, among others, by providing services to Y during working hours resulting from the employment contract concluded with X despite the prohibition of using X's IT infrastructure for private purposes. In connection with the above, this employee was removed from the duties arising from the position (...). The President of the UODO received explanations from Y, from which the following findings arise (see: letters from Y sent to the supervisory authority: April 6, 2021, October 17, 2022, and November 17, 2023): 1) From the risk analysis of information security submitted by Y, conducted on June 4, 2018, it follows that the data administrator anticipated the risk of accidental disclosure of data to unauthorized persons. It was noted that this is possible, but only in the case of non-compliance with the implemented procedures, and as planned actions, random checks of employees processing personal data were indicated. This risk was accepted without the necessity of taking planned actions. An additional risk analysis was conducted on June 22, 2021. From Y's explanations, it does not appear that before the occurrence of the subject data protection breach, an analysis of the risk associated with the process of changing the payroll software was conducted, within which the process of copying data to a USB drive by an employee of the Company took place. However, Y indicated that it conducts an “information security” risk analysis every year, and the last one (conducted in October 2022) included, among other things, an assessment of the effectiveness of technical and organizational measures intended to ensure the security of processed data. 2) According to § (...) of the “Instruction (...)” (hereinafter referred to as “Instruction Y”), in the case of processing data on portable computers, hard drives and other used information carriers must be secured in a way that prevents access to this data by unauthorized persons (e.g., unauthorized access, theft of the computer, industrial espionage), through the use of cryptographic methods and means (encrypted partitions of hard drives, file encryption, physical protection of carriers). Additionally, in § (...) of Instruction Y, it was provided that persons using the IT system in which personal data is processed are prohibited, among other things, from copying data to information carriers, copying to other systems for the purpose of removing them from the workplace. However, the Employee X, who was employed by Y under a mandate contract, was not familiarized with the rules resulting from this Instruction. 3) Y, when asked by the supervisory authority whether it conducted regular testing, measuring, and evaluating the effectiveness of technical

and organizational measures to ensure the security of processed personal data before the occurrence of the subject data protection breach – especially in connection with the processing of data on USB drives (and was also asked to indicate whether such activities are conducted regularly by Y after the occurrence of the aforementioned breach), mainly pointed to the fact that annual risk analyses are conducted (including the analysis from October 2022), as mentioned in point 1 of this section. 4) In response to the question of how Y verified whether the Data Processor provides sufficient guarantees for the implementation of appropriate technical and organizational measures to ensure that processing meets the requirements of Regulation 2016/679, in accordance with Article 28(1) of this regulation, Y explained that it did not conduct a specific analysis of the technical and organizational measures used by the Company. It indicated that it chose a company that is well-known and has a good reputation in the local payroll software market, and also previously serviced other...

Entities in K. Following the incident, Y approached the Company with a request for information regarding the security measures it employs in the processing of entrusted data, and after obtaining this information, did not take any further control actions against the Company. 5) In the "Agreement (...)" concluded between Y and the Data Processor on December 29, 2020, the scope of entrusted data was specified, which was to include, in particular (but not exclusively) basic personal data (i.e.: first name, last name, phone number, electronic identification data) concerning Y's employees and contractors of this Administrator in the context of executing commercial contracts. This agreement also included the Data Processor's obligation to secure the entrusted personal data during processing by implementing appropriate technical and organizational measures that ensure an adequate level of security corresponding to the risks associated with the processing of personal data referred to in Article 32 of Regulation 2016/679 (§ (...)). In § (...) of this agreement, the Data Processor declared that it applies security measures that meet the requirements of Regulation 2016/679, which were listed in Annex No. 1 to this agreement. This annex provided, for example, certain principles regarding archival data carriers (which are to be adequately secured), and also indicated that remote access to data is realized solely through encrypted communication channels ((...)). In the analyzed factual situation, the Pendrive was not an archival data carrier, but rather one on which the recording of data was already unnecessary at the time of its loss (at least to some extent). The security measures specified in Annex No. 1 do not contain provisions significant from the perspective of the analyzed breach of personal data protection. 6) According to the report from the audit conducted by the Data Protection Officer of the City Office of K. from May 10 to 17, 2021, it was indicated that Employee X should have been granted authorization to process Y's personal data, and consequently, he should have been trained in personal data protection at Y and familiarized with the documentation regarding the protection of this data and the guidelines contained therein. The report also included information that Employee X explained that the personal data processed in the payroll and HR resources was provided to an Employee of the Company with the consent and knowledge of the Deputy Director of Y. 7) From Y's explanations, it follows that after the occurrence of the personal data breach, additional data protection training was conducted for administrative and cash employees. Furthermore, additional instructions regarding the granting of authorizations and the conclusion of data processing entrustment agreements were introduced. The President of the UODO received explanations from Z sp. z o.o. based in Ł., from which the following findings arise (see: letters from the Company sent to the supervisory authority: April 8 and May 12, 2021, and February 19, 2024), and took into account the explanations attached to Y's letter of October 17, 2022, and X's letter of August 12, 2021: 1) Before the occurrence of the incident, the Company conducted a risk analysis related to the process of changing the payroll and HR program of other entities. The Company also indicated that it had a data protection policy and procedures for transferring and storing data, and that it had signed data entrustment agreements with all its clients. 2) From the Policy (...) implemented in the Company, it follows, among other things, that taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity of threats, appropriate technical and organizational measures are implemented to ensure a level of security corresponding to this risk (point (...) of this Policy). Moreover, point (...) of this document contains provisions regarding conducting risk analysis to secure personal data adequately to the identified

threats. The Company has developed methods for transferring data that are continuously analyzed and tested – it has been producing and implementing payroll and HR systems for several years. At the time of transferring Data X and Y, the Company had not been using the method of transferring data on Pendrive-type carriers for several years – it uses electronic data transfer via disks (...) or (...). In this case – as explained by the Company – Employee X did not want to transfer data to the Company using this method (he transferred it on a Pendrive), and the Data Processor, wanting to download data for transfer to the HR system, had no choice in this matter. 3) The "Procedure (...)" introduced by the Data Processor (implemented in the Company since July 1, 2018, and in force at the time of transferring Data X and Y to the Pendrive) contained a provision (point (...)) stating that the transport of digital documents should take place through the transmission of data using digital platforms, via email, and portable drives such as Pendrives. There was no requirement for encrypting the carrier or the files contained on it, nor any other additional security measures. 4) The Company conducted (quote) "a risk analysis of data leakage" processed by it and, in connection with this, updated the policy (...). The Company discontinued the use of unencrypted Pendrive-type disks, and instead, only encrypted ones were introduced for use. A review of the laptops used was also conducted to check whether all disks are encrypted. Training on the security of data storage and transfer was also conducted. 5) The Employee of the Company who lost the Pendrive containing the data of Data Subjects X and Y received a reprimand. Furthermore, X, in a letter received by this Office on August 12, 2021, submitted, based on Article 78 § 1 in conjunction with Article 75 § 1 of the Administrative Procedure Code, the following evidence requests: 1) for the hearing of a witness.

****Finders of the Pendrive regarding the following facts:****

1. a) What were the circumstances of the discovery of the Pendrive by the Finder - in particular, whether the Finder witnessed the event of the Pendrive being lost,
b) Whether the contents of the Pendrive were made available by the Finder, including whether they were copied in any way to third parties, including whether, in a physical sense, during the period from the discovery of the Pendrive to its return to the entitled entity, the possession of this medium was transferred to any third party; (this evidentiary request was reiterated in letter X dated September 28, 2022);
2. To conduct evidence from ten specified documents (including two statements made by the Finder: on February 3 and June 28, 2021).

After reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:

Article 5 of Regulation 2016/679 formulates the principles regarding the processing of personal data, which must be respected by all controllers, i.e., entities that independently or jointly with others determine the purposes and means of processing personal data. In this case, X and Y performed this function in the processing of personal data.

According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("integrity and confidentiality"). Further provisions of the regulation specify this principle.

According to Article 5(2) of Regulation 2016/679, the controller is responsible for complying with the provisions of paragraph 1 and must be able to demonstrate compliance ("accountability"). As indicated in the Guidelines 07/2020 on the concepts of controller and processor contained in the GDPR (hereinafter referred to as: "Guidelines 07/2020") of the European Data Protection Board (quote): "The purpose of incorporating the principle of accountability into the GDPR and making it a key principle was to emphasize that data controllers must implement appropriate and effective measures and be able to demonstrate compliance with the regulations. The principle of accountability is further clarified in Article 24 (...). The principle of accountability is also reflected in Article 28, which specifies the obligations of the controller when using the services of a processor."

Pursuant to Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and

purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity, the controller implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate it. These measures are reviewed and updated as necessary. This means that when assessing the adequacy of security measures, the controller should take into account factors and circumstances related to processing (e.g., the type, method of processing data) and the risks associated with it. At the same time, the implementation of appropriate security measures is an obligation that is a manifestation of the realization of the general principle of data processing – the principle of integrity and confidentiality, as specified in Article 5(1)(f) of Regulation 2016/679. The implementation of technical and organizational measures should involve the controller implementing appropriate regulations, principles of personal data processing in the organization, but also conducting regular reviews of these measures, and if necessary, updating previously adopted security measures. The principle of integrity and confidentiality, expressed in Article 5(1)(f) of Regulation 2016/679, is also specified by other provisions of this legal act, i.e., Article 25(1) and Article 32(1) and (2).

According to the content of Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity arising from processing, the controller – both when determining the means of processing and during the processing itself – implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide the necessary safeguards for processing in order to meet the requirements of this regulation and protect the rights of data subjects.

According to Article 28(1) of Regulation 2016/679, if processing is to be carried out on behalf of the controller, the controller shall use only the services of those processors that provide sufficient guarantees to implement appropriate technical and organizational measures so that the processing meets the requirements of this regulation and protects the rights of data subjects. According to Article 28(3) of Regulation 2016/679, processing by the processor shall be governed by a contract or other legal instrument that is subject to Union law or the law of a Member State and binds the processor and the controller, specifying the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects, the obligations and rights of the controller. This contract or other legal instrument shall in particular stipulate that the processor:

- a) processes personal data only on documented instructions from the controller – this also applies to the transfer of personal data to a third country or an international organization – unless required to do so by Union law.

under the law of the Member State to which the processor is subject; in such a case, before commencing processing, the processor informs the controller of this legal obligation, unless the law prohibits providing such information due to a significant public interest; b) ensures that persons authorized to process personal data are committed to confidentiality or are subject to an appropriate statutory obligation of confidentiality; c) takes all measures required under Article 32; d) complies with the conditions for using the services of another processor referred to in paragraphs 2 and 4; e) taking into account the nature of the processing, assists the controller, where possible, by means of appropriate technical and organizational measures to fulfill the obligation to respond to requests from the data subject regarding the exercise of their rights as specified in Chapter III; f) considering the nature of the processing and the information available to it, assists the controller in fulfilling the obligations specified in Articles 32-36; g) after the completion of the services related to processing, depending on the controller's decision, deletes or returns all personal data and deletes any existing copies unless Union law or the law of the Member State requires the retention of personal data; h) provides the controller with all information necessary to demonstrate compliance with the obligations set out in this article and allows the controller or an auditor authorized by the controller to conduct audits, including inspections, and contributes to them. In connection with the obligation specified in the first paragraph letter h), the processor shall promptly inform the controller if, in its opinion, an instruction issued to it constitutes a breach of this regulation or other Union or Member State data

protection provisions.

From the content of Article 32(1) of Regulation 2016/679, it follows that the controller and the processor are obliged to implement technical and organizational measures corresponding to the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity of the threat. The provision specifies that when deciding on technical and organizational measures, account must be taken of the state of the technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity.

From the cited provision, it follows that determining appropriate technical and organizational measures is a two-step process. First, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32 of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, in accordance with letters b) and d) of this article, should include measures such as the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, as well as regular testing, measuring, and evaluating the effectiveness of the technical and organizational measures designed to ensure the security of processing.

Article 32(2) of Regulation 2016/679 states that when assessing whether the level of security is appropriate, particular consideration shall be given to the risks associated with processing, in particular those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

The provisions of Regulation 2016/679 therefore impose specific obligations regarding the security of processed personal data on both controllers and processors. According to Articles 32(1) and 2 of Regulation 2016/679, both types of entities are obliged to adopt appropriate technical and organizational measures to ensure a level of security corresponding to the risk associated with the processing of personal data. In this case, it is necessary to first examine whether the relevant entities, before taking actions aimed at implementing changes to the payroll system, properly conducted the aforementioned two-step process, i.e.: 1) whether they conducted a risk analysis associated with such actions, as changing the payroll system (in which data is processed on such a broad scope as in the case of Data X and Data Y) is an action introducing a change in the existing course of personal data processing and as such should be preceded by detailed analyses to determine the impact of this action on the security of processed data, 2) whether (based on the aforementioned analysis) they identified and implemented technical and organizational measures ensuring a level of security for personal data processed in this system corresponding to that risk.

For the risk analysis to be conducted properly, full knowledge of the structure of all elements of the data processing system is necessary, both for the processing itself and for its protection against – in this case – unauthorized access. It should also be emphasized that any changes in programs used for processing personal data (especially those requiring the transfer or replication of data) require the data controller, as well as the processor, to first verify whether the previously conducted risk analysis takes into account the threats associated with this action. If not, it is their obligation to...

conducting such an analysis to identify those threats and determine security measures that reduce the likelihood of their occurrence to an acceptable risk level. Regulation 2016/679 introduced an approach in which risk management is the foundation of activities related to the protection of personal data and is characterized as an ongoing process. Data processors are obliged not only to ensure compliance with the guidelines of the aforementioned regulation through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to provide accountability regarding the level and adequacy of the implemented safeguards. This means that it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk, as well as taking into account the nature of the organization and the mechanisms used for processing personal data. The consequence of such an orientation is the abandonment of lists of requirements

regarding security imposed by the legislator in favor of independently selecting safeguards based on a threat analysis. Entities participating in the data processing process are not provided with specific security measures and procedures—they are to independently conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk.

Considering the above, it is worth noting the judgment of the Administrative Court in Warsaw dated October 5, 2023, case reference II SA/Wa 502/23, which stated that: “First and foremost, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria specified in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These findings, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services, the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, and regular testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of processing.” “For the proper fulfillment of the obligations arising from the above-mentioned provisions of Regulation 2016/679, the Administrator should first conduct a risk analysis and, based on it, determine and implement adequate measures to ensure security in the process of processing personal data. In the event that the Administrator has anticipated the possibility of using computer equipment (on which personal data is processed) outside their premises, the analysis in question should indicate potential risks arising from the possibility of its theft (both of company equipment and personal equipment belonging to employees, on which work-related activities are performed) used in connection with the provision of work outside the organization’s premises.”

On the other hand, the Supreme Administrative Court in its judgment dated February 9, 2023, case reference III OSK 3945/21, stated that: “Under the GDPR, the legislator has moved away from a static definition of the technical and organizational measures required from the administrator in favor of a dynamic assessment of the adopted security measures. This means that it is the responsibility of the administrator and the data processor to determine appropriate (adequate) security measures, while maintaining the competence of the supervisory authority to verify the adopted level of safeguards.”

It should be emphasized that risk analysis and risk management are processes that require the cooperation of all interested parties and, as such, require primarily planning, organizing, directing, and controlling the resources used for processing, the execution of the processing activities themselves, and the examination and detection of potential vulnerabilities and gaps. In particular, it is necessary to analyze the impact of any change on the level of security of the processed data. Consequently, before undertaking any actions, including those involving changes to the existing data processing process aimed at changing the payroll and personnel program, each data administrator and data processor should exercise the utmost caution, and before implementing the change itself, they should establish the principles for its introduction, especially in the context of ensuring an appropriate level of security for the processed data, and verify whether the individual stages of the operation have been completed successfully not only in terms of the system's operational efficiency but also in terms of meeting the requirements of legal regulations (including the provisions of Regulation 2016/679 imposing obligations regarding ensuring an appropriate level of data security). In this case, such a targeted analysis was not conducted, merely relying on general assumptions. Y, in the risk analysis conducted by them a year and a half before the occurrence of the data protection breach in question, anticipated the risk of accidental disclosure of data to unauthorized persons, and as planned actions indicated random checks of employees processing personal data. X indicated that they did not conduct a risk analysis related "strictly to the process of changing the payroll and personnel program, as the scope of the processed data remained the same, just as the data processing process in the program, and the decision to change was caused solely by the fact, to the Processor regarding the specific measures to be taken in order to ensure data security, raises significant concerns about the adequacy of the security measures implemented in the context of the

data processing activities undertaken by X, Y, and the Processor.

1. ****Insufficient Compatibility****

It has been established that the previous program was insufficiently compatible with the computers and other programs used by X K. type “(...)”. It should be noted that in the event of a significant change in the manner of processing personal data, which involves the necessity of “transferring” the processed data, a risk analysis related to such a change should be conducted. The mere fact that the scope of the processed data remains the same is irrelevant in this case.

2. ****Risk Analysis****

The Company conducted a risk analysis related to the process of changing the payroll program for its clients; however, the Company Employee – in the event of refusal to provide the data necessary for him to perform the appropriate actions by Employee X – acted contrary to the methods of operation of the Company mentioned in point 16 subpoint 2 (on page 12 of this decision). The evidence gathered in the case does not indicate that X or Y conducted any risk analysis related to the process of transferring data to the new payroll program, and the Company did not conduct the aforementioned risk analysis in the context of using portable data carriers.

3. ****Assessment of Actions****

In assessing the correctness of the actions of X, Y, and the Processor in the above context, it should be emphasized that the risk analysis in question should have been conducted by all three entities, not just the Processor, whose actions in this regard were also inadequate for the event that occurred.

4. ****Findings****

The findings made in this case allow us to conclude that X, Y, and the Processor conducted an insufficient risk analysis related to the actions taken to change the payroll program, which required the transfer of personal data (including: they did not conduct a risk analysis related to the loss of the carrier containing this personal data), while its proper execution would have allowed for the selection of appropriate security measures. For the proper execution of the second stage of the aforementioned process, it is essential that the preceding first stage is executed correctly.

5. ****Consideration of Risks****

In the case of the aforementioned actions taken by the Company in this matter, the risk of losing the data carrier on which the personal data of Data Subjects X and Y were recorded and leaving this carrier in a location accessible to unauthorized persons should have been taken into account. It should also be considered that the person who would come into possession of such a carrier could have the means to read its contents (hence, whether the Finder of the Pendrive became acquainted with this content is irrelevant in assessing the correctness of the actions of X and Y and the Company in the context of the risk analysis related to the implementation of the new payroll program and processing of Data X and Y).

6. ****Security Measures****

Considering this risk, the entities on which obligations are imposed under Article 32(1) and (2) of Regulation 2016/679 could have decided, for example, to encrypt the contents of the Pendrive, to set access passwords for the Pendrive itself or for folders containing personal data, or to subject files containing such data to encryption or pseudonymization. This would have allowed for the avoidance of a breach of personal data protection even in the event of the loss of the data carrier.

7. ****Limitations of X and Y****

In this case, X and Y limited themselves to instructing the Processor to transfer personal data (within the framework of the contracts concluded in this regard), without explicitly indicating how this transfer should take place. There are reasonable grounds to assume that both X and Y assumed that this would occur in accordance with internal procedures regarding the principles of personal data processing and in accordance with the general principles indicated in the contracts (...) concluded with the Company.

8. ****Validity of Assumptions****

Considering the validity of this assumption, it should first be pointed out that Employee X provided Data X contrary to Instruction X (the Pendrive was not secured). Secondly, it should be emphasized that Employee X, who was also employed by Y, was not familiarized with the principles of personal data processing in Y. This employee was employed by Y under a mandate contract, and on January 4, 2021, a data processing entrustment agreement was concluded with him instead of granting him authorization to process data (this irregularity was pointed out in the report from the audit task conducted on May 17, 2021, in Y, second paragraph on page 3). This employee processed data with the knowledge and consent of the Deputy Director of Y, so in the event that he was not trained in the aforementioned principles, he should have received specific instructions regarding the method of transferring Data Y or the methods of securing them – it could not be assumed in such a situation that this employee should bear full responsibility for the decisions made in this regard.

9. ****Responsibilities of the Administrator****

Similarly, the administrator should not assume that the processor will take into account the general principles of operation resulting from internal regulations regarding the principles of personal data processing. The Employee of the Processor did not have to know the content of Instruction X or Instruction Y. The contract (...) concluded with the Company by X on November 16, 2020, and the contract concluded in this regard on December 29, 2020, contained only the Processor's obligation to secure the entrusted personal data during processing by applying appropriate technical and organizational measures ensuring an adequate level of security corresponding to the risk associated with the processing of personal data referred to in Article 32 of Regulation 2016/679. The same obligation was included in the Agreement (...) concluded by Y with the Company on December 29, 2020. The above-cited provision, which appeared in all three aforementioned agreements, is very general – its content is essentially a repetition of the obligation contained in this article of Regulation 2016/679. This fact, combined with the lack of guidance provided to the Processor regarding the specific measures to be taken to ensure data security, raises significant concerns about the adequacy of the security measures implemented in the context of the data processing activities undertaken by X, Y, and the Processor.

The Processor by X and Y regarding the method of securing data during its transfer to the new payroll and HR program indicates that the administrators assumed that the Processor would conduct a risk analysis related to such actions and select appropriate technical and organizational measures to ensure the security of this data. However, the obligations in this regard rest both on X and Y, as well as on the Processor, and the fact that one of them takes action does not exempt the other from the obligations imposed on them by Article 32(1) and (2) of Regulation 2016/679. The findings made in this matter do not allow for the conclusion that X and Y took actions aimed at implementing the two-step process referred to in the aforementioned provision. The Processor also did not demonstrate, in a manner that raises no serious doubts, the correctness of the actions it took, in particular, it did not secure the files on the Pendrive against unauthorized access and did not delete unnecessary data, contrary to its own procedure. As previously cited, from point (...) of the Policy (...) introduced in the Company, it follows, among other things, that considering the state of technical knowledge, the cost of implementation, as well as the nature, scope, context, and purposes of processing and the risk of infringement of the rights or freedoms of individuals with varying probabilities of occurrence and severity of threats, appropriate technical and organizational measures are implemented to ensure a level of security corresponding to that risk. On the other hand, from point (...) of the Procedure (...) in force in the Company at the time of replicating Data X and Y on the Pendrive, it followed that the transport of digital documents should take place through the transmission of data using digital platforms, via email, and portable drives such as Pendrives. There was no requirement for encrypting the medium or the files contained on it, nor any other additional security measures. The selection of such technical and organizational measures indicates a failure to consider in the risk analysis the possibility of leaving the data medium in an unsecured location against access by unauthorized persons. These measures were not adequate to this type of risk.

It is obvious that when selecting technical and organizational measures, their effectiveness should be verified considering current technical capabilities, as well as potential threats. Measures that were

appropriate at one time may not remain effective under changed circumstances. It should also be remembered that measures, even if appropriately selected for the current possible risk of infringement of personal data protection, should be regularly tested. These actions (involving continuous verification of the adequacy and effectiveness of the selected measures and regular testing of those already in use) constitute – as a whole – the fulfillment of the obligation provided for in Article 32(1)(b) of Regulation 2016/679 (the ability to continuously ensure confidentiality). In the event of a change in the payroll and HR program and the transfer of Data X and Y, it seems clear that tests regarding the security measures applied should have been conducted both before and after the transfer of this data. Their proper execution would have allowed for the detection of the error that occurred, namely, leaving unnecessary data (especially Data Y) on the Pendrive, and subsequently: leaving the Pendrive in an unknown location of the Company, which was not secured against access by unauthorized persons. The obligation to conduct such tests, in accordance with Article 32(1)(d) of Regulation 2016/679, rests both on the processor and the data controller. From the explanations provided by the Company, it follows that it regularly tested, measured, and assessed the effectiveness of the technical and organizational measures aimed at ensuring the security of processed personal data, but from the fact that for several years it had not used portable media when transferring data, one must conclude that it did not carry out the aforementioned actions regarding the processing of data on employees' business Pendrives. The explanations from X and Y also do not indicate that they performed such tests.

As previously indicated, the correct selection of technical and organizational measures considering possible risks and regular testing, including verification of the correctness of employees' performance of their duties (e.g., sharing data only on encrypted media, or not leaving data media in locations unsecured against access by unauthorized persons) would have allowed in this situation to avoid an infringement of personal data protection. It should be assumed that the obligations of entities participating in the process of personal data processing should not end with the aforementioned two-step process, i.e., conducting a risk analysis and applying appropriate technical and organizational measures to ensure the security of processed personal data. Consequently, based on this assumption, it should be stated that both X, Y, and the Processor should have verified whether personal data was shared in a manner that considered the risk of losing its medium, as well as whether it was adequately secured against access by unauthorized persons. The lack of such verification, in light of the failure to implement any technical and organizational measures aimed at securing personal data (e.g., by requiring a password to open all files or folders containing personal data) on the Pendrive, resulted in an infringement occurring. Actions regarding the implementation of appropriate technical measures (i.e., for example, introducing a requirement for encrypting data media such as Pendrives by the Company) were only carried out after the occurrence of the infringement of personal data protection.

In light of the above findings, it must be stated that

****Lack of actions by both X, Y, and the Data Processor****

to conduct a risk analysis for the purpose of making changes to the payroll program and transferring the Data of X and Y using a USB drive, determining and applying adequate technical and organizational measures to ensure data security during this operation, and verifying the correctness of actions taken by employees, resulted in a violation of Article 32(1) and (2) of Regulation 2016/679. Proper testing conducted in the framework of the requirement from Article 32(1)(d) should have also included the handling of the USB drive after transferring part of the data to the hard drive at the Company's headquarters and allowed for verification of whether the selection of implemented security measures (which should have been assessed for their effectiveness already at the stage of implementing this solution) was appropriate. Meanwhile, among other things, due to inadequate verification of the correctness of the actions taken, neither X, nor Y, nor the Data Processor realized for over two weeks that an unsecured USB drive had been unintentionally left in a location accessible to unauthorized persons – the breach was detected as a result of information provided by the Finder. Irregularities in this area obviously affect the assessment of compliance by X, Y, and the Data Processor with their obligation arising from Article 32(1)(b) of Regulation 2016/679 (the ability to continuously ensure confidentiality).

When discussing the obligations arising from Article 32(1)(d) of Regulation 2016/679, it should also be noted that X conducted an audit of the Data Processor only after the breach of personal data security was identified (on March 5, 2021) – unfortunately, this was a delayed action. Y, in turn, did not conduct such an audit even subsequently. It should not be forgotten that the administrator's oversight of the actions of the data processor is an important organizational measure aimed at protecting the security of processed personal data. In a judgment dated June 6, 2023, case reference II SA/Wa 1939/22, the Provincial Administrative Court in Warsaw indicated that "(...) the obligation to regularly test technical and organizational measures securing the processing of personal data, in order to ensure a level of security appropriate to the risk, in the sense of Article 32(1) introductory sentence of the GDPR, directly stems from the wording of point (d) of the indicated Article 32(1), while the obligation to document actions in this area is established by the principle of accountability (Article 5(2) of the GDPR)." The Court expressed a similar view in its judgment dated June 21, 2023, case reference II SA/Wa 150/23.

It should also be pointed out that the obligations regarding the implementation of appropriate technical and organizational measures to ensure that processing is carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for processing, so as to meet the requirements of this regulation, have been imposed on the data controller (and only on the data controller) by the provisions of Article 24(1) and Article 25(1) of the aforementioned regulation. Given the lack of application by X and Y of adequate security measures, as mentioned above, it should be concluded that they also violated these provisions of Regulation 2016/679. The consequence of their violation is the necessity to state that the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679 has also been breached, as well as the principle of accountability referred to in Article 5(2) of Regulation 2016/679, obliging the controller to comply with the principles arising from Article 5(1) of Regulation 2016/679 and to demonstrate such compliance. The above is confirmed by the ruling of the WSA in Warsaw dated February 10, 2021, case reference II SA/Wa 2378/20: "The principle of accountability is therefore based on the legal responsibility of the controller for properly fulfilling obligations and imposes on them the obligation to demonstrate, both before the supervisory authority and before the data subject, evidence of compliance with all data processing principles."

A similar interpretation of the principle of accountability is provided by the WSA in Warsaw in its judgment dated August 26, 2020, case reference II SA/Wa 2826/19: "Considering the entirety of the norms of Regulation 2016/679, it should be emphasized that the controller has significant discretion regarding the security measures applied, while at the same time bearing responsibility for violations of data protection regulations. The principle of accountability directly implies that it is the data controller who should demonstrate, and thus prove, that they comply with the provisions specified in Article 5(1) of Regulation 2016/679."

Taking into account the entirety of the above considerations, it should be stated that ensuring security (including confidentiality) of processed data is a key issue from the perspective of the entities involved in their processing. The Provincial Administrative Court in Warsaw in its judgment dated November 15, 2023, case reference II SA/Wa 552/23, stated that: "(...) the authority correctly decoded the concept of 'data confidentiality' as a certain property that ensures that data will not be made available to unauthorized entities. This can be achieved, among other things, by applying technical and organizational measures appropriate to the scope of data, the context of processing, and identified risks."

Given the demonstration above that X, Y, and the Data Processor did not fulfill the obligations imposed on each of them as specified in Article 32(1) and (2) of Regulation 2016/679 regarding risk analysis and the selection of appropriate technical and organizational measures to ensure the security of processed data, an additional in-depth analysis of certain aspects of the relationship between X and Y (acting as the data controllers of Data X and Y, respectively) and the Data Processor (including in the context of Article 32(1) and Article 28(3) of Regulation 2016/679) should be conducted, i.e., among other things, whether the actions...
of personal data and categories of data subjects, as well as the obligations and rights of the controller,

which contract must include, in particular, the elements specified in points a) to h) of this provision.

In the examined factual state, the agreement (...) concluded between X and the Processor on December 29, 2020 – unlike the agreement concluded on this matter between the same parties on November 16, 2020 – essentially contained the elements required by Article 28(3) of Regulation 2016/679, although many aspects of this agreement would benefit from further elaboration to avoid a situation similar to the one in which the aforementioned breach of personal data protection occurred.

Unfortunately, the situation with the agreement (...) concluded also on December 29, 2020, between Y and the Processor is different. This agreement was very similar in content to the agreement concluded on this matter between X and the Processor on December 29, 2020, but unlike it, it did not adequately specify the type of personal data entrusted for processing. It only indicated (in § (...) the basic personal data of Y's employees and its contractors, i.e., first names, last names, phone numbers, as well as electronic identification data. As already indicated in an earlier part of this justification, the data of Y, whose protection was breached, had a significantly broader scope. Of course, it should be noted that the agreement contained the phrase "in particular" in this point, but it is impossible not to notice that it omitted all data of greater significance from the perspective of protecting the rights or freedoms of the natural persons affected by this breach, such as, for example, PESEL identification numbers or salary data. Therefore, it should be concluded that the agreement concluded on December 29, 2020, between Y and the Processor did not contain the element indicated in Article 28(3) sentence one of Regulation 2016/679, i.e., the type of personal data (according to this provision, processing by the processor takes place on the basis of a contract or other legal instrument, which is subject to Union law or the law of a member state and binds the processor and the controller, specifying the subject and duration of processing, the nature and purpose of processing, the type of personal data and categories of data subjects, as well as the obligations and rights of the controller, which contract must include, in particular, the elements specified in points a) to h) of this provision).

personal data and the categories of individuals to whom the data pertains, the obligations and rights of the controller). Based on the explanations provided by X and Y, as well as the Data Processor, it is impossible to confirm that the implemented changes were carried out according to predetermined principles ensuring the security of personal data - the technical and organizational measures intended to ensure this security were not detailed either in the general regulations implemented by the controller or in the relevant agreement concluded between each of the controllers and the Data Processor on December 29, 2020. Moreover, the instruction to implement the new payroll and HR program was not communicated by X or Y along with any guidance on methods to ensure the security of the processed data. On the contrary: the manner of their implementation was to be determined by the Data Processor, whose obligation to apply appropriate organizational and technical measures stemmed from the agreements concluded on December 29, 2020 (...). The discretion in choosing the solutions used by the Data Processor, combined with inappropriate conduct by Employee X and the lack of oversight regarding the correctness of actions taken in this regard, ultimately led to a breach of personal data protection.

In light of the above (i.e., the determination that the agreements (...) concluded by X and Y with the Data Processor did not contain provisions regarding the manner of performing actions related to data processing in connection with the change of the payroll and HR program), it is necessary to further analyze whether such actions by X and Y could have stemmed from a justified certainty regarding the competence of the Data Processor.

In this case, X - when asked how he verified whether the data processor provides sufficient guarantees for the implementation of appropriate technical and organizational measures to ensure that data processing meets the requirements of Regulation 2016/679, in accordance with Article 28(1) of that regulation - explained that he has been cooperating with the Company for about 30 years and that the previous cooperation had been successful and exemplary. He also explained that the Data Processor indicated, prior to signing the agreement, the security measures in the appropriate annex to that agreement, which solutions were accepted by X, and he noted that "[o]nly after fulfilling these solutions was the agreement signed," and that the Controller, each time signing an agreement with the data

processor, verified the level of security of personal data with that entity and the fulfillment of obligations arising from Regulation 2016/679. As previously demonstrated in the justification of this decision, this annex did not contain provisions significant from the perspective of the circumstances leading to the occurrence of the breach of personal data protection.

On the other hand, Y, responding to the same question, explained that he did not conduct a specific analysis of the technical and organizational measures used by the Company. He indicated that he chose a company that is well-known and had a good reputation in the local payroll software market and had previously serviced other entities in K.

In response to the above explanations from X and Y, it should be noted that: - under the previous legal state, based on the Act of August 29, 1997 on the Protection of Personal Data (Journal of Laws of 2016, item 922), different requirements were defined for the data processor, while different ones have been in effect since May 25, 2018, i.e., from the moment the application of Regulation 2016/679 began. Therefore, the previously positively assessed cooperation can only serve as a starting point in verifying whether the data processor provides sufficient guarantees for the implementation of appropriate technical and organizational measures to ensure that processing meets the requirements of Regulation 2016/679 and protects the rights of the individuals whose data is concerned. The requirement specified in Article 28(1) of Regulation 2016/679 is absolutely binding on every data controller who, in the course of their activities, uses the resources or services of a data processor when processing personal data. It should be emphasized that the obligation to conduct such an assessment is not waived by the fact of long-term cooperation and the use of services of a given data processor before May 25, 2018, i.e., before the application of Regulation 2016/679 began. Neither X nor Y conducted such verification: X limited himself to a positive assessment of the Data Processor, which was the result of previous cooperation established even before the application of the provisions of Regulation 2016/679 began, while Y relied on information about the good opinion of the Company in the local market. The consequence of failing to conduct this assessment is a violation of the requirement specified in Article 28(1) of Regulation 2016/679. It should be noted that merely signing a data processing agreement without conducting an appropriate assessment of the data processor cannot be considered as fulfilling the obligation to conduct a verification procedure regarding the data processor in terms of meeting the requirements of Regulation 2016/679; - long-term cooperation of the parties not supported by periodic, systematic audits or inspections does not guarantee that the data processor will properly fulfill the tasks required by law and arising from the concluded data processing agreement. At this point, it should be noted that in the agreement (...) connecting both X and Y with the Data Processor from December 29, 2020, provisions were included regarding X and Y's right to control whether the measures applied by the Data Processor in processing and securing the entrusted personal data comply with the provisions of this agreement - these actions could therefore have been carried out before the occurrence of the breach of personal data protection. The issue of criteria for assessing the data processor.

was also the subject of considerations by the European Data Protection Board. As indicated in Guidelines 07/2020, referring to the content of Article 28(1) and Recital 81 of Regulation 2016/679, (quote): "The controller is (...) responsible for assessing the adequacy of the guarantees provided by the processor and should be able to demonstrate that it has seriously considered all elements provided for in the GDPR. The guarantees 'provided' by the processor are those that the processor can satisfactorily demonstrate to the controller, as these are the only guarantees that the controller can effectively take into account when assessing the fulfillment of its obligations. This will often require the exchange of appropriate documentation (e.g., privacy policies, terms of service, records of processing activities, document management policies, information security policies, reports from external data protection audits, recognized international certifications, such as ISO 27000 standards). The controller's assessment of whether the guarantees are sufficient is a form of risk assessment that largely depends on the type of processing entrusted to the processor and must be carried out individually for each case, taking into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. (...) The controller should take into account the following elements (...) to assess whether the guarantees are sufficient:

expertise (e.g., technical knowledge regarding security measures and data breaches); the credibility of the processor; the resources of the processor. The reputation of the processor in the market may also be an important factor that controllers should consider. Furthermore, compliance with an approved code of conduct or certification mechanism can be used as an element to demonstrate sufficient guarantees. (...) The obligation to use only the services of processors 'providing sufficient guarantees' contained in Article 28(1) of the GDPR is a continuous obligation. It does not end at the moment of concluding a contract or other legal act by the controller and the processor. Rather, the controller should periodically verify the guarantees of the processor, including, where appropriate, through audits and inspections (...).

In summary of the previous discussion, it should be noted that the circumstances of leaving a USB drive, the contents of which were not secured against unauthorized access, in an arbitrary location, were related to actions taken to implement a new payroll program in X and Y, whereby the Processor conducted its activities under contracts with these entities that did not specify either the method of processing (including transferring) data or the security measures that were to be maintained. Moreover, in carrying out these processes, the Processor did not exercise due diligence – it did not remove unnecessary data from the USB drive (contrary to the procedure in force in the Company), and the correctness of the course of these processes was not verified after their completion (nor during). Therefore, the Processor did not fulfill the requirements specified in Articles 32(1) and (2) of Regulation 2016/679. However, when assessing the actions taken by the Processor, it should be noted not only that § (...) of each of the "Contracts (...)" concluded between X and Y and the Processor states that the Company committed to exercise due diligence in processing the entrusted personal data, but also the fact that no specific instructions were provided to it in this regard, compliance with which would be controlled by the controllers.

From the above, it follows that the causes of the occurrence of the infringement in question should also be sought in the improper organization and management of the process of implementing the new payroll program. It should be pointed out that neither X nor Y at any stage of the changes being introduced conducted oversight over whether these changes were actually proceeding correctly and whether the processed personal data were secured against unauthorized access (such oversight constitutes an organizational measure aimed at ensuring the security of processed personal data). As mentioned earlier in this justification, Article 32(1)(d) of Regulation 2016/679 imposes an obligation to regularly test, measure, and assess the effectiveness of technical and organizational measures to ensure the security of processing. Conducting reviews and updating implemented solutions is also a requirement explicitly stated in Article 24(1) of Regulation 2016/679, as well as resulting from Article 25(1) of Regulation 2016/679, which creates an obligation to ensure privacy protection by design (privacy by design) and imposes on the controller the obligation to implement appropriate technical measures both at the stage of determining the methods of processing and at the stage of processing itself (it should be emphasized again that the obligations specified in Articles 24(1) and 25(1) of Regulation 2016/679 are solely the responsibility of the controller). The implementation by the controller of technical and organizational measures is not a one-time action but should take the form of a process, within which the controller reviews and updates previously adopted security measures as necessary. Such an assessment should apply not only to technical measures but also to organizational ones, i.e., the procedures implemented by the Controller regarding the processing of personal data, including procedures for making changes to the programs used for processing personal data. Regular assessment of the aforementioned procedures, in accordance with the requirement arising from Article 32(1)(d) of Regulation 2016/679, would allow X and Y to verify whether the effectiveness of such procedures is crucial, meaning that they ensure appropriate actions are taken to protect personal data during the process of making changes to the programs used for processing personal data and whether they are actually adhered to by those responsible for implementing these changes.

In the matter at hand, in the opinion of the President of the UODO (Personal Data Protection Office), the verification by X and Y of how the Data Processor implements changes related to the program in

which personal data was processed would significantly reduce the risk of unauthorized access to the data processed in that program, thereby minimizing the risk of infringement of the rights or freedoms of the individuals whose data is processed by X and Y. This is because the infringement of personal data protection occurred as a result of an obvious error consisting of leaving a USB drive unsecured against access by unauthorized persons to the data contained on it, which should have been detected during the verification of the correctness of the subsequent phases of the payroll program change process. The consequence of the above omission was the lack of actions by X and Y to ensure the security of personal data, including that of their employees, to which they were obligated under the aforementioned provisions of Regulation 2016/679, as administrators of that data.

It should also be emphasized that the fact of using the services of a data processor does not exempt the administrator from fulfilling these obligations. The responsibilities in this regard primarily rest with the data administrator. Analyzing the actions (or rather the lack of actions) of X and Y in this area, one can conclude that they limited themselves to commissioning the Data Processor to implement a new payroll program, without taking any actions to verify whether security for the processing of personal data of Data Subjects X and Y was ensured during the process of making changes.

The collected material in the case also confirms that prior to the initiation of administrative proceedings, X and Y did not conduct audits, including inspections, at the data processor to check whether the Company properly fulfills its obligations arising from Regulation 2016/679 (including whether it ensures the application of the measures required under Article 32 of this regulation). The possibility of conducting such audits, including inspections, arises from Article 28(3)(h) of Regulation 2016/679, according to which the data processing agreement must stipulate that the data processor provides the administrator with all information necessary to demonstrate compliance with the obligations specified in this article and allows the administrator or an auditor authorized by the administrator to conduct audits, including inspections, and contributes to them. This provision thus gives the administrator certain tools, the use of which can ensure that the processing of entrusted data complies with the provisions of Regulation 2016/679, and that the administrator avoids liability for their violation.

It should be emphasized that conducting audits, including inspections, by the administrator at the data processor should be regarded as one of the most important security measures that the administrator should apply to properly fulfill their obligations arising from Article 32(1) of Regulation 2016/679. The administrator should, during their use of the services of the data processor, have knowledge of whether and how the entity to which they entrusted the processing of personal data meets the requirements specified in Regulation 2016/679. There is no doubt that the most effective way for the administrator to ensure this knowledge is through conducting appropriate audits, including inspections, at the data processor. However, X and Y did not apply such security measures, which consequently contributed to the occurrence of a personal data breach. Furthermore, the application of the aforementioned measures is linked to the obligation of the data administrator arising from Article 28(1) of Regulation 2016/679, which means that its execution must also confirm whether the data processor continues to guarantee the implementation of appropriate technical and organizational measures to ensure that processing meets the requirements of Regulation 2016/679 and protects the rights of the individuals concerned.

The lack of audits (prior to the audit conducted following the occurrence of the personal data breach in question), including inspections, at the data processor also constitutes a violation of Article 25(1) of Regulation 2016/679. This provision obliges the implementation of appropriate technical and organizational measures not only when determining the methods of processing but also during the processing itself. The continuity inherent in the analyzed obligation may therefore manifest itself in practice, among other things, in the necessity to ensure regular monitoring of the applied safeguards and maintaining ongoing supervision over the data processor through, for example, audits and inspections referred to in Article 28(3)(h) of Regulation 2016/679.

In the opinion of the President of the UODO, the technical and organizational measures applied by X and Y only partially met the requirements specified in Article 32 of Regulation 2016/679, due to the fact

that they did not implement appropriate procedures ensuring the security of the processed data during the implementation of the new payroll program in which this data is processed, nor did they supervise the Data Processor regarding the actions taken to implement this program. It should be emphasized that ensuring...

by the data administrator of supervision and monitoring of development work on systems commissioned to external entities, is one of the fundamental organizational measures that the administrator should effectively implement to ensure the security of personal data in accordance with the requirements arising from Regulation 2016/679. Consequently, the failure of X and Y to apply the above principles has resulted in foreseeable risks not being adequately minimized and limited during processing.

It should be recognized that the application of appropriate security standards regarding changes in IT systems used for processing personal data, including their verification for security, and in particular compliance with the requirements arising from Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679, as well as effective verification of the actions of the Data Processor in this regard, would significantly reduce the risk of unauthorized access to Data X and Y, thereby minimizing the risk of infringement of the rights or freedoms of natural persons whose data is processed by X and Y, i.e., the disclosure of data to unauthorized recipients.

At this point, it is worth recalling the judgment of the Administrative Court in Warsaw of August 26, 2020, case reference II SA/Wa 2826/19, in which the Court indicated that "The adopted measures must be effective (...)" and "(...) actions of a technical-organizational nature lie within the competence of the personal data administrator, but cannot be selected in a completely arbitrary and voluntary manner, without taking into account the level of risk and the nature of the protected personal data," as well as the judgment of that court of January 19, 2021, case reference II SA/Wa 702/20, that "Personal data should be processed in a manner that ensures appropriate security and confidentiality, including protection against unauthorized access to them and to the equipment used for their processing and against unauthorized use of such data and equipment (recital 39 of Regulation 2016/679)."

In summary, the findings do not provide a basis for stating that the technical and organizational measures employed by X, Y, and the Data Processor to ensure the security of personal data were adequate to the state of technical knowledge, the costs of implementation, and the nature, scope, context, and purposes of processing, which consequently did not ensure effective implementation of data protection principles. Consequently, in the opinion of the President of the Personal Data Protection Office (UODO), both X, Y, and the Company did not implement appropriate technical and organizational measures to ensure the security of personal data being processed in the context of transferring them to the newly implemented payroll and HR program, which constitutes a violation of Article 32(1) and (2) of Regulation 2016/679.

In making this summary, it should be reiterated that the obligations regarding the implementation of appropriate technical and organizational measures to ensure that processing is carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for processing to meet the requirements of this regulation have been imposed on the data administrator (and only on the data administrator) by the provisions of Article 24(1) and Article 25(1) of Regulation 2016/679. Given the lack of application by X and Y of adequate security measures, as mentioned above, it should be concluded that X and Y also violated these provisions of Regulation 2016/679. The consequence of their violation is the necessity to state that the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679 has also been violated. It should be emphasized that the proper and effective safeguarding of data has been elevated in Regulation 2016/679 to the status of a general principle, indicating that the issue of ensuring data confidentiality should be treated in a special and prioritized manner by the data administrator. Meanwhile, as already demonstrated in the justification of this decision, both X, Y, and the Data Processor did not implement appropriate technical and organizational measures to ensure the security of personal data processing, which led to a violation by X and Y of their confidentiality in connection with the occurrence of a personal data breach, i.e., a violation of the principle referred to in Article 5(1)(f) of Regulation 2016/679. As shown in this

justification, X and Y also violated Article 5(2) of Regulation 2016/679 (which defines the principle of accountability) and Article 28(1) of Regulation 2016/679. Furthermore, the agreement concluded on December 29, 2020, by Y with the Data Processor did not contain all the elements specified in Article 28(3) first sentence of Regulation 2016/679, i.e., it did not properly specify the type of data being processed. Meanwhile, in Guidelines 07/2020, it was indicated that (quote): "Although the elements specified in Article 28 of the Regulation constitute its essential content, the agreement should serve as a means for the administrator and the data processor to further clarify how to implement these essential elements through detailed instructions," and also that (quote): "In any case, the agreement must include all elements of Article 28(3). At the same time, the agreement should contain certain elements that may help the data processor understand the risks to the rights and freedoms of the data subjects arising from processing: since the activity is carried out on behalf of the administrator, the administrator often has a greater understanding of the risks associated with processing because they are aware of the circumstances in which processing takes place." The agreement, on the other hand, should be drawn up in writing, which has also been emphasized in the aforementioned Guidelines (quote): "(...) unwritten agreements (regardless of their level of detail or effectiveness) cannot be considered sufficient to meet the requirements specified in Article 28 of the GDPR."

In justifying the issued decision, reference should be made to the previously mentioned evidentiary requests submitted under Article 78 § 1 in conjunction with Article 75 § 1 of the Administrative Procedure Code (KPA) by X in a letter received by this Office on August 12, 2021, namely:

- 1) to hear the Finder of the Pendrive as a witness regarding the following facts:
 - a) what were the circumstances of the Finder discovering the Pendrive in question - in particular, whether the Finder witnessed the event of the Pendrive being lost,
 - b) whether the contents of the Pendrive were shared by the Finder, including whether they were copied in any way to third parties, specifically whether, in a physical sense, during the period from the discovery of the Pendrive to its return to the entitled entity, the possession of this medium was transferred to any third party; (this evidentiary request was reiterated in X's letter dated September 28, 2022);
- 2) to conduct evidence from ten specified documents (including two statements made by the Finder: on February 3 and June 28, 2021).

The President of the Personal Data Protection Office (UODO) took into account the content of the aforementioned ten documents. Given that two of these documents are statements from the Finder regarding the circumstances of their possession of the Pendrive and that they did not use, copy, transfer, or disclose to third parties any data contained on the Pendrive, the President of UODO deemed the evidentiary request from X in point 1) above to be irrelevant for the proper establishment of the factual state.

According to Article 78 § 1 of the KPA, the authority conducting the proceedings is obliged to consider the evidentiary request of a party if the subject of the evidence is a circumstance relevant to the case. In doctrine, it is accepted that the assessment of whether the subject of the evidence is a circumstance relevant to the case or not belongs to the authority, not to the party. This means that the authority conducting the proceedings is not bound by the evidentiary requests of the party. However, the authority is bound in this regard by the provisions of substantive law that form the basis for the decision. Therefore, it will be up to the authority to decide whether to admit a given piece of evidence or not. There is no doubt that the authority should first consider whether the circumstance for which the party has invoked an evidentiary measure requires proof.

According to the judgment of the Supreme Administrative Court (NSA) of August 4, 2017 (case file I OSK 1607/16, LEX no. 2345355), in every proceeding, the authority has the obligation to gather evidence relevant to the resolution of the case and to make the necessary factual findings based on that evidence. However, what factual findings are necessary to resolve the case is determined by correctly interpreted provisions of substantive law, not by the subjective conviction of the party. No authority conducting proceedings is obliged to conduct all the evidence requested by the party. The

evidentiary measures indicated by the party cannot be omitted only if the disputed facts relevant to the resolution of the case have not been clarified. This means that only the failure to establish circumstances relevant to the case can be considered a violation of procedural rules that could affect the content of factual findings and, consequently, the content of the decision concluding the proceedings in a given case. The entitlement of the party provided for in Article 78 of the KPA is subject to limitations due to the expediency and speed of the proceedings. The authority may not consider a request to conduct evidence if it aims to prolong the case (judgment of the Supreme Administrative Court of November 29, 2016, case file II GSK 3322/15, LEX no. 2230883).

The President of UODO deemed the evidentiary request from X to hear the Finder of the Pendrive as a witness to be irrelevant to the case, as in their opinion, the evidence gathered in the case is sufficient for its resolution, and the authority is not obliged to consider all the requests of the party.

At this stage of the proceedings, the supervisory authority did not find any doubts that would need to be clarified by the testimony of the Finder of the Pendrive, and furthermore, it concluded that the gathered evidence is sufficient to issue an administrative decision (of which X, Y, and the Company were notified by letters dated August 14, 2024).

In assessing the circumstances of the violation of personal data protection, it should be emphasized that when applying the provisions of Regulation 2016/679, it should be borne in mind that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of recital 1 of the preamble). In the event of any doubts, for example, regarding the fulfillment of obligations by administrators - not only in situations where there has been a violation of personal data protection but also when developing technical and organizational security measures to prevent such violations - these values should be prioritized.

In light of the above findings, the President of the Personal Data Protection Office, exercising the authority granted to them under Article 58(2)(i) of Regulation 2016/679, according to which each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a)-(h) and (j) of this regulation, an administrative fine under Article 83(4)(a) and (5)(a) of Regulation 2016/679, taking into account the circumstances established in the proceedings, stated that...

In the case under consideration, there were grounds justifying the imposition of administrative monetary penalties on X, Y, and the Data Processor. According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the controller and the processor, referred to in Articles 8, 11, 25 - 39, and 42 and 43, are subject to an administrative monetary penalty of up to EUR 10,000,000, or in the case of an enterprise, up to 2% of its total worldwide annual turnover from the previous financial year, with the higher amount applying. According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject to an administrative monetary penalty of up to EUR 20,000,000, or in the case of an enterprise, up to 4% of its total worldwide annual turnover from the previous financial year, with the higher amount applying. Article 83(3) of Regulation 2016/679 states that if the controller or processor intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative monetary penalty does not exceed the amount of the penalty for the most serious violation. According to the Guidelines 04/2022 of the European Data Protection Board (hereinafter: "EDPB") on calculating administrative monetary penalties under the GDPR adopted on May 24, 2023 (hereinafter referred to as "Guidelines 04/2022"), the term "total amount" means that when assessing the amount of the monetary penalty, all violations committed must be taken into account, and the formulation "the amount of the penalty for the most serious violation" refers to the statutory maximum amounts of monetary penalties (e.g., Articles 83(4)-(6) of the GDPR).

Furthermore, according to Article 102(1)(1) of the Act on the Protection of Personal Data (u.o.d.o.), the

President of the Personal Data Protection Office (UODO) may impose, by way of a decision, administrative monetary penalties of up to PLN 100,000 on entities in the public finance sector referred to in Article 9(1-12 and 14) of the Act of August 27, 2009, on public finances (Journal of Laws of 2023, item 1270, as amended). Both X and Y are entities to which this penalty limit applies. The administrative monetary penalties referred to in paragraphs 1 and 2 are imposed by the President of the Office based on and under the conditions specified in Article 83 of Regulation 2016/679 (Article 102(3) of the u.o.d.o.).

In this case, the administrative monetary penalty imposed on X was for violating Article 25(1), Article 28(1), Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for violating Article 5(1)(f) and Article 5(2) of Regulation 2016/679 – based on Article 83(5)(a) of that regulation. At the same time, the penalty of PLN 15,000 imposed on X for the violation of all the above provisions – in accordance with Article 83(3) of Regulation 2016/679 – does not exceed the amount of the penalty for the most serious violation established in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which, according to Article 83(5)(a) of Regulation 2016/679, is subject to an administrative monetary penalty of up to EUR 20,000,000, or in the case of an enterprise, up to 4% of its total worldwide annual turnover from the previous financial year, nor does it exceed the penalty limit specified in Article 102(1)(1) of the u.o.d.o.

In this case, the administrative monetary penalty imposed on Y was for violating Article 25(1), Article 28(1) and (3), Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for violating Article 5(1)(f) and Article 5(2) of Regulation 2016/679 – based on Article 83(5)(a) of that regulation. At the same time, the penalty of PLN 20,000 imposed on Y for the violation of all the above provisions – in accordance with Article 83(3) of Regulation 2016/679 – does not exceed the amount of the penalty for the most serious violation established in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which, according to Article 83(5)(a) of Regulation 2016/679, is subject to an administrative monetary penalty of up to EUR 20,000,000, or in the case of an enterprise, up to 4% of its total worldwide annual turnover from the previous financial year, nor does it exceed the penalty limit specified in Article 102(1)(1) of the u.o.d.o.

The administrative monetary penalty imposed on the Data Processor for violating Article 32(1) and (2) and Article 32(1) and (2) in conjunction with Article 28(3)(c) and (f) of Regulation 2016/679 is based on Article 83(4)(a) of Regulation 2016/679. In deciding to impose an administrative monetary penalty on X, the President of UODO – in accordance with the provisions of Article 83(2)(a-k) of Regulation 2016/679 – took into account the following circumstances of the case, which are aggravating and have an impact on the amount of the imposed financial penalty:

The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679).

In determining the administrative monetary penalty, it was significant that the violation of the provisions of Regulation 2016/679, which impose obligations on the controller regarding the application of appropriate technical and organizational measures...

in order to ensure the security of the processed personal data, has impacted the breach of confidentiality of data of five hundred forty-nine Data Subjects X. The breach of the provisions of Regulation 2016/679 identified in this case, resulting in unauthorized access to the aforementioned personal data, is of significant weight and serious nature, as it may lead to material or non-material damages for the individuals whose data has been compromised, and the high probability of such occurrences cannot be excluded due to the lack of security of the Pendrive. Furthermore, it is necessary to consider the risk arising from the broad scope of data covered by the breach of personal data protection that occurred in this case, the relatively large number of data subjects, as well as the relatively large scale and professional nature of data processing (X, as a public institution trusted by citizens, should guarantee knowledge of and respect for applicable legal regulations - including those concerning personal data protection).

Analyzing the factual state in question, it must be stated that there has undoubtedly been a loss of control over the processed personal data by the entities responsible for ensuring an appropriate level of their protection. It should also be emphasized that the mere breach of data confidentiality also constitutes non-material damage (harm). A data subject may at least feel fear of losing control over their personal data, identity theft, or identity fraud, or finally, fear of financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Moreover, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of *Natsionalna agentsia za prihodite* (C-340/21) emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a person whose data is concerned experiences as a result of a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

Additionally, it should be emphasized that the breach of the provisions of Regulation 2016/679 that occurred in this situation had particular circumstances – it infringes upon the interests of employees whose data X should protect. Considering the aspect of the purpose of processing, it should be noted that the processing of employees' personal data requires particular diligence, where there is an imbalance between X (the employer or contractor) and the data subjects (employees or contractors).

It should be assumed that the breach of the provisions of Article 5(1)(f), Article 5(2), Article 25(1), Article 28(1), and Article 32(1) and (2) of Regulation 2016/679 lasted from 2020, when X took steps to change the previously used payroll and HR program, which included, among other things: selecting a supplier for the new program (which process should have included verifying this entity against the requirements set out in Article 28(1) of Regulation 2016/679), signing a data processing agreement with the Processor, and sharing this data with the Company. The President of the UODO in this case accepted that the breach of the aforementioned provisions of Regulation 2016/679 by X had ended, as the process of implementing the new payroll and HR program (involving the transfer of X's Data) was completed in 2021, in which year there was also an audit of the Processor's actions related to the processing of X's Data.

Unintentional nature of the breach (Article 83(2)(b) of Regulation 2016/679). The breach of the provisions by X occurred due to its failure to exercise due diligence, and indeed: gross negligence – the sharing of X's Data occurred through its replication on an unsecured Pendrive accessible to unauthorized persons. The sharing occurred contrary to the procedures in force at X – nonetheless, it bears responsibility as the administrator for the identified irregularities in the data processing process. X, deciding to change the payroll and HR program, did not conduct a risk analysis related to data processing using portable data carriers by capturing it in the form of strictly defined, precise explanatory formulas and organizing the course of this process. X was unable to demonstrate that by implementing technical and organizational measures to ensure compliance of processing with Regulation 2016/679, it ensured that the level of security of personal data was appropriate. X did not provide instructions to the Processor regarding how the replicated personal data should be secured when access to this data in remote form was denied to the Employee of the Processor.

Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The data of X, which are subject to the breach of the provisions of Regulation 2016/679 (in which data the Finder and potentially also other unknown and unauthorized third parties gained possession), belong, among other things, to special categories of personal data referred to in Article 9 of Regulation 2016/679. This data had a broad scope: first names, surnames, parents' names, date of birth, bank account number, residential or temporary address, PESEL identification number, data concerning earnings and/or owned assets, maiden name of the mother, series and number of the identity card, phone number, health-related data (data concerning the absence of contraindications), to employment, data contained in medical certificates of occupational medicine), as well as other data: place of birth, citizenship, data regarding work time records (including, among others, data on vacations, medical leaves), information about health and safety training, method of payment (bank name), information about remuneration, data regarding completed schools, employment history (data

contained in work certificates), names and surnames of children and their dates of birth (and additionally, NIP numbers and information contained in disability certificates, as indicated by X in the letter dated September 24, 2021). Such a broad scope is associated with a high risk of violation of the rights or freedoms of individuals affected by the violation. It should be emphasized that, in particular, the unauthorized disclosure of such a category of data as the PESEL identification number (in conjunction with the first name and surname) can realistically and negatively affect the protection of the rights or freedoms of individuals. The PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies an individual, containing, among other things, the date of birth and gender designation, is thus closely linked to the private sphere of the individual and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679. It is data of a special nature and requires such special protection. Furthermore, the inclusion of the national identification number in the data protection violation that occurred in this case allows for treating this premise as aggravating in accordance with Guidelines 04/2022. The fact that the disclosed data also included health-related data further increases the risk of violating the rights or freedoms of individuals to whom this data pertains.

In Guidelines 04/2022, it was indicated: "Regarding the requirement to consider the categories of personal data affected by the violation (Article 83(2)(g) [of Regulation 2016/679]), [the Regulation 2016/679] explicitly specifies the types of data that are subject to special protection, and thus a more rigorous response when imposing monetary penalties. This concerns at least the types of data covered by Articles 9 and 10 [of Regulation 2016/679] and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the individual to whom the data pertains (e.g., data concerning location, data concerning private communications, national identification numbers, or financial data, such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are involved in the violation or the more sensitive the data is, the greater weight the supervisory authority may assign to such a factor. The quantity of data concerning each individual to whom the data pertains is also significant, as the scale of the violation of the right to privacy and data protection increases with the amount of data concerning each individual."

In determining the amount of the administrative monetary penalty imposed on X, the President of the UODO considered the following mitigating circumstances: Actions taken to minimize the harm suffered by the individuals whose data is concerned (Article 83(2)(c) of Regulation 2016/679) – in this case, based on the collected evidence, the supervisory authority did not find any property damage on the part of the individuals affected by the violation (Data Subjects X). It should be noted that immediately after the disclosure of the personal data breach, even before the initiation of administrative proceedings, measures were taken to secure the data from further breaches, i.e., from remaining in the possession of unauthorized persons, and an appropriate audit of the Data Processor was conducted. As indicated above, the mere breach of data confidentiality also constitutes non-material damage (harm); however, the actions taken to secure the data from being accessed by other unauthorized entities should be assessed as a mitigating circumstance, as, in the opinion of the President of the UODO, narrowing the circle of entities that could unlawfully access Data X should be considered as actions taken to minimize the harm suffered by the individuals whose data is concerned.

The degree of cooperation with the supervisory authority to eliminate the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679) - X provided comprehensive explanations in response to the supervisory authority's requests and engaged in remedial and preventive actions (conducting an audit and implementing appropriate changes).

The fact that the President of the UODO imposed an administrative monetary penalty on X in this case, as well as its amount, was not influenced by other circumstances indicated in Article 83(2) of Regulation 2016/679, namely:

1. The degree of responsibility of X, taking into account the technical and organizational measures implemented under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The findings made by the President of the UODO allow for the conclusion that X did not fulfill its obligations regarding

supervision over the Data Processor during the implementation of actions aimed at changing the payroll and personnel program (in terms of the protection of Data X), which consequently led to freedom in undertaking the aforementioned actions by the Data Processor, i.e., carrying out work aimed at implementing a new payroll and personnel program without conducting ongoing and post-implementation checks of the correctness of these actions and securing the processed personal data from access by unauthorized persons. The lack of any oversight over the process of implementing changes concerning the program in which the data was processed...

personal data, results in a high degree of responsibility for X for the breach of personal data confidentiality. However, X's fulfillment of obligations under Articles 25 and 32 of Regulation 2016/679 is one of the subjects of these proceedings, and in the circumstances of the considered factual state, the supervisory authority has accepted that it will not treat this condition as an aggravating circumstance (given that the administrative fine imposed in the analyzed case is related to the violation of these specific provisions of Regulation 2016/679).

2. Relevant previous violations of the provisions of Regulation 2016/679 (Article 83(2)(e) of Regulation 2016/679) – The President of the UODO did not find any prior violations of data protection regulations committed by X, which is why there are no grounds to treat this circumstance as aggravating. And since such a state (compliance with data protection regulations) is a natural state resulting from the legal obligations imposed on X, it cannot also have a mitigating effect on the assessment of the violation made by the President of the UODO.

3. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679) – The President of the UODO identified the violation of the provisions as a result of a report of a personal data breach made, among others, by X; however, given that X, in making this report, was merely fulfilling a legal obligation, there are no grounds to consider this circumstance as a mitigating factor. According to the Guidelines on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP 253, "The supervisory authority may become aware of a violation as a result of proceedings, complaints, articles in the press, anonymous tips, or notification by the data controller. According to the regulation, the controller is obliged to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor." Similarly, the EDPB approaches this issue in Guidelines 4/2020, which state that in cases where the controller is subject to specific obligations regarding the reporting of data breaches (e.g., the obligation specified in Article 33 of Regulation 2016/679), the fact of making such a report should be considered a neutral circumstance.

4. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679) – Before issuing this decision, the President of the UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against X in the case under consideration, which is why X had no obligation to take any actions related to their application, and such actions, assessed by the President of the UODO, could have had an aggravating or mitigating effect on the assessment of the identified violation.

5. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679) – X does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for controllers and processors, as stipulated by the provisions of Regulation 2016/679, which is why the circumstance of their non-application cannot be considered against X in this case. On the other hand, the circumstance of adopting and applying such instruments as means guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of X.

6. Any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained directly or indirectly in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not identify any other aggravating or mitigating factors applicable to the circumstances of the case. He also did not find that X had obtained any financial benefits or avoided such losses in connection with the violation.

Therefore, there are no grounds to treat this circumstance as aggravating for X. The identification of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, X's failure to achieve such benefits, as a natural state independent of the violation and its effects, is a circumstance that, by its very nature, cannot be mitigating for him. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" – which occurred on the part of the entity committing the violation.

The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the administrative fine imposed on X, which should be taken into account in the context of the consideration of the condition in Article 83(2)(k) of Regulation 2016/679.

In the opinion of the President of the UODO, the administrative fine imposed on X in the amount of 15,000 PLN (in words: fifteen thousand zlotys) fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case.

In the opinion of the President of the UODO, the fine imposed on X is proportional both to the severity of the violation (resulting in a breach of one of the fundamental principles on which the regulation is based).

****2016/679 Personal Data Protection System – Principles of Data Confidentiality****

as well as in relation to the size of the administrator.

At the same time, in the opinion of the President of the UODO, the penalty at this level will be effective (achieving the goal of punishing X for a serious violation with significant consequences) and deterrent for the future (causing X to pay due attention to the processing of personal data through and with the help of the Processor, using the rights granted to it under the data processing entrustment agreement). A lower penalty for this entity could, in practice, go unnoticed and could leave room for calculating whether the costs of administrative monetary penalties for this organization would be lower than the expenditures on personal data protection.

In light of the above, the President of the UODO further indicates that the administrative monetary penalty imposed on X meets, in particular, the criterion of proportionality of the penalty as understood in the case law of the CJEU (in the context of competition law and in relation to decisions of the European Commission, but which, in the opinion of the President of the UODO, has a more general application): "[...] the principle of proportionality requires that acts issued by the institutions of the Union do not exceed the limits of what is appropriate and necessary to achieve the legitimate objectives pursued by the provisions in question, whereby where there is a possibility of choosing from a greater number of appropriate solutions, the least burdensome should be applied, and the resulting inconveniences must not be excessive in relation to the intended objectives [...]" (see judgment of December 12, 2012, *Electrabel / Commission*, T-332/09, EU:T:2012:672, para. 279 and the case law cited therein)" (see judgment of October 26, 2017, in case T-704/14 *Marine Harvest ASA v. Commission*, para. 580).

In this context, it should be noted that the monetary penalty of 15,000 PLN (in words: fifteen thousand zlotys) imposed on X meets the criteria referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the established violation in the context of the fundamental objective of Regulation 2016/679, namely the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data. At the same time, the amount of the administrative monetary penalty imposed by this decision on X, which is a unit of the public finance sector (as indicated in Article 9 of the Act of August 27, 2009 on Public Finances), falls within the limit of 100,000 zlotys specified in Article 102(1) of the Personal Data Protection Act.

In deciding to impose an administrative monetary penalty on Y, the President of the UODO – in accordance with the provisions of Article 83(2)(a-k) of Regulation 2016/679 – took into account the

following circumstances of the case, which are aggravating and have an impact on the amount of the imposed financial penalty:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). In determining the administrative monetary penalty, the circumstance that the violation of the provisions of Regulation 2016/679, imposing obligations on the administrator regarding the application of appropriate technical and organizational measures to ensure the security of processed personal data, affected the confidentiality of data of approximately one thousand Data Subjects Y was of significant importance. The violation of the provisions of Regulation 2016/679 established in this case, resulting in unauthorized access to the aforementioned personal data, is of considerable weight and serious nature, as it may lead to material or non-material damage to the individuals whose data has been compromised, and the high probability of such occurrences cannot be ruled out due to the lack of security of the Pendrive. Furthermore, the risk arising from the broad scope of data covered by the data protection violation in this case, the relatively large number of data subjects, as well as the relatively large scale and professional nature of the data processing must also be taken into account (Y, as a public institution endowed with the trust of citizens, should guarantee knowledge and respect for the applicable legal provisions – including those concerning the protection of personal data).

Analyzing the factual state in question, it must be stated that there has undoubtedly been a loss of control over the processed personal data by the entities responsible for ensuring an appropriate level of their protection. It should also be emphasized that the mere violation of data confidentiality also constitutes non-material damage (harm). The data subject may at least feel fear of losing control over their personal data, identity theft, or identity fraud, or finally, fear of financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, fear, and thus loss of security, constitutes a real non-material damage associated with the obligation to remedy it. In turn, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of Natsionalna agentsia za prihodite (C-340/21) emphasized that “Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a data subject experiences following a breach of this regulation, may in itself constitute ‘non-material damage’ within the meaning of this provision.”

Moreover, it should be emphasized that the violation of the provisions of Regulation 2016/679 that occurred in this situation had particular circumstances – it infringes on the interests of employees whose data Y should have protected.

****Protect.**** Considering the aspect of the purpose of processing, it should be noted that the processing of personal data of employees requires particular diligence, as there is an imbalance between Y (the employer) and the data subjects (employees or collaborators).

It should be assumed that the violation of the provisions of Article 5(1)(f), Article 5(2), Article 25(1), Article 28(1) and (3), and Article 32(1) and (2) of Regulation 2016/679 lasted from 2020, when Y took steps to change the previously used payroll program, which included, among other things: the selection of a new program provider (a process that should have included verification of this entity in terms of the requirements set out in Article 28(1) of Regulation 2016/679), signing a data processing agreement with the Data Processor (where the agreement (...) concluded on December 29, 2020, did not contain all the properly defined elements required under Article 28(3) of Regulation 2016/679), and sharing this data with the Company. The President of the UODO in this matter concluded that the violation of the aforementioned provisions of Regulation 2016/679 by Y had ended, among other reasons, because the process of implementing the new payroll program (involving the transfer of Y's data) was completed in 2021 (and a new agreement (...) was concluded on February 8, 2021, and it was - according to Y's statement - corrected).

2. ****Unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679).**** The violation of the provisions by Y occurred due to his failure to exercise due diligence, and indeed: gross negligence - the sharing of Y's data occurred through its replication on an unsecured USB drive accessible to

unauthorized persons. The sharing occurred contrary to the procedures in force at Y - nevertheless, he bears responsibility as the administrator for the identified irregularities in the data processing process. Y, by deciding to change the payroll program, did not conduct a risk analysis related to data processing using portable data carriers by presenting it in the form of strictly defined, precise explanatory formulas and organizing the course of this process. Y was unable to demonstrate that by implementing technical and organizational measures to ensure compliance of processing with Regulation 2016/679, he ensured that the level of security of personal data was appropriate. Y did not provide instructions to the Data Processor regarding how the replicated personal data should be secured when access to this data in remote form was denied to the Employee of the Data Processor. Furthermore, it should be emphasized that this administrator did not even familiarize Employee X, who was employed at Y under a mandate contract, with the applicable procedures at Y regarding personal data protection, and also allowed the replication of Y's Data on a USB drive by the Data Processor operating under a data processing agreement that did not contain properly defined elements specified in Article 28(3) of Regulation 2016/679.

3. **Categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679).**
The data of Y, which is the subject of the violation of the provisions of Regulation 2016/679 (in which data the Finder gained possession and potentially also other unknown and unauthorized third parties) had a wide scope: first names, surnames, parents' names, dates of birth, bank account numbers, residential or temporary addresses, PESEL identification numbers, email addresses, data regarding earnings and/or owned assets, maiden names of mothers, series and numbers of identity cards, and phone numbers. Such a wide scope is associated with a high risk of violation of the rights or freedoms of the natural persons affected by the violation. It should be emphasized that in particular, the unauthorized disclosure of such a category of data as the PESEL identification number (in conjunction with the first name and surname) can realistically and negatively affect the protection of the rights or freedoms of natural persons. The PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, contains, among other things, the date of birth and gender designation, and is therefore closely linked to the private sphere of the natural person and is also subject, as a national identification number, to special protection under Article 87 of Regulation 2016/679, is data of a special nature and requires such special protection. Furthermore, the inclusion of the national identification number in the violation of personal data protection that occurred in this case allows this criterion to be treated as aggravating in accordance with the Guidelines 04/2022.

In the Guidelines 04/2022, it is stated: "Regarding the requirement to consider the categories of personal data affected by the violation (Article 83(2)(g) [of Regulation 2016/679]), Regulation 2016/679 clearly indicates the types of data that are subject to special protection, and thus a more rigorous response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 [of Regulation 2016/679] and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., data concerning location, data concerning private communication, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are affected by the violation or the more sensitive the data, the greater weight the supervisory authority may assign to such a factor. The quantity of data concerning each individual whose data is affected is also significant, as the scale of the violation of the right to privacy increases with the amount of data concerning each individual whose data is affected.

"and the protection of personal data."

In determining the amount of the administrative monetary penalty imposed on Y, the President of the UODO considered the following mitigating circumstances:

1. Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679) – in this case, based on the collected evidence, the supervisory authority did not find any material damages suffered by the individuals affected by the breach (Data Subjects of Y). It should be noted that immediately after the disclosure of the personal data breach, even before the initiation of administrative proceedings, measures were taken to secure the data against further breaches, i.e., to

prevent their continued possession by an unauthorized person. As indicated above, the mere breach of data confidentiality also constitutes non-material damage (harm); however, the actions taken to secure the data against being accessed by other unauthorized entities should be assessed as a mitigating circumstance, as in the opinion of the President of the UODO, narrowing the circle of entities that could unlawfully access Data Y should be regarded as actions taken to minimize the damage suffered by the data subjects.

2. The degree of cooperation with the supervisory authority in order to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679) – Y provided comprehensive explanations in response to the supervisory authority's requests and engaged in remedial and preventive actions (implementation of appropriate changes).

The fact that the President of the UODO imposed an administrative monetary penalty on Y in this case, as well as its amount, was not influenced by other circumstances specified in Article 83(2) of Regulation 2016/679, namely:

1. The degree of responsibility of Y, taking into account the technical and organizational measures implemented pursuant to Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The findings made by the President of the UODO allow for the conclusion that Y did not fulfill its obligations regarding supervision over the Data Processor during the implementation of actions aimed at changing the payroll and personnel program (in terms of the protection of Data Y), which consequently led to freedom in undertaking the aforementioned actions by the Data Processor, i.e., carrying out work aimed at implementing a new payroll and personnel program without conducting ongoing and post-execution control of the correctness of these actions and securing the processed personal data against access by unauthorized persons. The lack of any supervision over the process of implementing changes concerning the program in which personal data was processed results in a high degree of responsibility for Y for the breach of data confidentiality. However, the fulfillment by Y of the obligations under Articles 25 and 32 of Regulation 2016/679 is one of the subjects of this proceeding, and in the circumstances of the considered factual state, the supervisory authority accepted that this circumstance would not be treated as an aggravating factor (given that the administrative monetary penalty imposed in this case is related to the breach of these specific provisions of Regulation 2016/679).

2. Relevant previous breaches of the provisions of Regulation 2016/679 (Article 83(2)(e) of Regulation 2016/679) – the President of the UODO did not find any previous breaches of personal data protection regulations committed by Y, which means there are no grounds to treat this circumstance as aggravating. And since such a state (compliance with personal data protection regulations) is a natural state resulting from the legal obligations imposed on Y, it cannot also have a mitigating effect on the assessment of the breach made by the President of the UODO.

3. The manner in which the supervisory authority became aware of the breach (Article 83(2)(h) of Regulation 2016/679) – the President of the UODO identified the breach of regulations as a result of a report of a personal data breach made, among others, by Y; however, since Y, in making this report, was merely fulfilling its legal obligation, there are no grounds to consider this circumstance as a mitigating factor. According to the Guidelines on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679 WP 253, "The supervisory authority may become aware of a breach as a result of proceedings, complaints, articles in the press, anonymous tips, or notification by the data controller. According to the regulation, the controller has an obligation to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor." Similarly, the EDPB approaches this issue in Guidelines 4/2020, which state that in cases where the controller is subject to specific obligations regarding the reporting of personal data breaches (e.g., the obligation specified in Article 33 of Regulation 2016/679), the fact of making this report should be considered a neutral circumstance.

4. Compliance with previously applied measures in the same case referred to in Article 58(2) of

Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679) – Prior to issuing this decision, the President of the UODO did not apply any measures against Y in the examined case as mentioned in Article 58(2) of Regulation 2016/679, which means that Y had no obligation to take any actions related to their implementation, and such actions, assessed by the President of the UODO, could have a burdening or mitigating effect on the assessment of the identified breach.

5. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms pursuant to Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679) – Y does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not – as provided by the provisions of Regulation 2016/679 – mandatory for controllers and processors, which means that the circumstance of their non-application cannot be considered against Y in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of Y.

6. Any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained directly or indirectly in connection with the violation or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of UODO did not find the existence of any other aggravating or mitigating factors applicable to the circumstances of the case. He also did not find that Y had obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds for treating this circumstance as aggravating for Y. The determination of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, Y's failure to achieve such benefits, as a natural state independent of the violation and its effects, is a circumstance that, by its very nature, cannot be mitigating for him. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" – that is, those that occurred on the part of the entity committing the violation.

The President of UODO, having comprehensively considered the case, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the administrative monetary penalty imposed on Y, which should be taken into account in the context of the consideration of the criterion from Article 83(2)(k) of Regulation 2016/679.

In the opinion of the President of UODO, the administrative monetary penalty imposed on Y in the amount of 20,000 PLN (in words: twenty thousand zlotys) fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case.

In the opinion of the President of UODO, the penalty imposed on Y is proportional both to the seriousness of the violation (resulting in a breach of one of the fundamental principles on which the data protection system in Regulation 2016/679 is based – the principle of data confidentiality) and to the size of this controller. At the same time, its amount takes into account, among other things, the fact that in the case of Y, the violation of the provisions occurred to a greater extent than in the case of X by entrusting the processing of personal data to the Company based on a contract that did not contain all the elements required under Article 28(3) of Regulation 2016/679.

At the same time, in the opinion of the President of UODO, the penalty at this level will be effective (it will achieve the goal of punishing Y for a serious violation with serious consequences) and deterrent for the future (it will cause Y, in order to avoid further sanctions, to pay due attention to the processing of personal data through and with the help of the Processor, using the rights granted to him under the data processing entrustment agreement). A lower penalty for this entity could practically go unnoticed and could leave room for calculating whether the costs of administrative monetary penalties for this organization would not be lower than the expenditures on the protection of personal data.

In light of the above, the President of UODO also indicates that the administrative monetary penalty imposed on Y particularly meets the criterion of proportionality of the penalty in the sense developed in

the case law of the CJEU (in the context of competition law and in relation to decisions of the European Commission, but which, in the opinion of the President of UODO, has a more general application): “[...] the principle of proportionality requires that acts issued by the institutions of the Union do not exceed the limits of what is appropriate and necessary to achieve the legitimate objectives served by the provisions in question, and where there is a possibility of choosing from a number of appropriate solutions, the least burdensome should be adopted, and the resulting disadvantages must not be excessive in relation to the intended objectives [...] (see judgment of December 12, 2012, *Electrabel / Commission*, T-332/09, EU:T:2012:672, para. 279 and the case law cited therein)” (see judgment of October 26, 2017, in case T-704/14 *Marine Harvest ASA v. Commission*, para. 580).

In connection with the above, it should be noted that the monetary penalty in the amount of 20,000 PLN (in words: twenty thousand zlotys) imposed on Y meets, in the established circumstances of this case, the criteria referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the established violation in the context of the fundamental objective of Regulation 2016/679 – the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data. At the same time, the amount of the administrative monetary penalty imposed by this decision on Y, which is a unit of the public finance sector (as indicated in Article 9 of the Act of August 27, 2009 on public finances), falls within the limit of 100,000 zlotys specified in Article 102(1) of the Personal Data Protection Act.

In deciding to impose an administrative monetary penalty on the Company, the President of UODO – in accordance with the provisions of Article 83(2)(a-k) of Regulation 2016/679 – took into account... the following circumstances of the case, which have a burdensome effect and influence the determination of the imposed financial penalty:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing in question, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). In determining the administrative monetary penalty, it was significant that the violation of the provisions of Regulation 2016/679, which impose obligations on the Data Processor regarding the application of appropriate technical and organizational measures to ensure the security of personal data being processed, affected the confidentiality of data concerning approximately one thousand five hundred individuals (Data Subjects X and Y). The violation resulted from the Data Processor's failure to apply basic security principles aimed at securing personal data against unauthorized access. The Data Processor, providing professional services, including the implementation of a payroll program and possessing appropriate knowledge in this area, did not apply security principles, including failing to verify the correctness of the processes being carried out (it was not checked whether unnecessary data had been deleted from the Pendrive when it was transferred to the hard drive of the company's computer). The violation of personal data protection established in this case, which allowed unauthorized persons access to personal data, is of considerable weight and serious nature, as it may lead to material or non-material damages for the individuals whose data has been compromised, and the high probability of such damages occurring cannot be excluded due to the lack of security of the Pendrive. Furthermore, it is necessary to consider the risk arising from the wide scope of data covered by the personal data breach that occurred in this case, the relatively large number of data subjects, as well as the relatively large scale and professional nature of the data processing. Analyzing the factual state in question, it must be stated that there was undoubtedly a loss of control over the processed personal data by the entities responsible for ensuring an appropriate level of their protection. It should also be emphasized that the mere breach of data confidentiality also constitutes a non-material damage (harm). The data subject may at least feel apprehensive about losing control over their personal data, identity theft, or identity fraud, or finally, about financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, the fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of

Natsionalna agentsia za prihodite (C-340/21) emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a person whose data is concerned experiences as a result of a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

It should be assumed that the violation of the provisions of Articles 32(1) and (2) and Articles 32(1) and (2) in conjunction with Article 28(3)(c) and (f) of Regulation 2016/679 lasted from 2020 when the Data Processor undertook actions aimed at changing the payroll program previously used in X and Y, which actions included, among others, the processing of entrusted Data X and Y. The President of UODO in this case assumed that the violation of the aforementioned provisions of Regulation 2016/679 by the Data Processor had ended, as the process of implementing new payroll programs (involving the transfer of Data X and Y) was completed in 2021.

2. The unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). The violation of the provisions by the Company arose as a result of its failure to exercise due diligence, and indeed: gross negligence. The Company, as the data processor, is responsible for the identified irregularities in the data processing process - it must have been obvious to the Data Processor that in the analyzed factual state, there was an unauthorized disclosure of personal data in a manner inconsistent with the standard practice of obtaining such data adopted in the Company (as of the date of data replication to the Pendrive, which was described in point 16, subpoint 2 on page 12 of this decision). Above all, due to the failure to conduct a risk analysis associated with data processing using portable data carriers by capturing it in the form of strictly defined, precise explanatory formulas and organizing the course of this process, the Company was unable to demonstrate that by implementing technical and organizational measures to ensure compliance of processing with Regulation 2016/679, it ensured that the level of security of personal data was appropriate.

3. Categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679). The personal data affected by the violation of the provisions of Regulation 2016/679 (in which data the Finder and potentially also other unknown and unauthorized third parties gained possession) includes, among others, special categories of personal data referred to in Article 9 of Regulation 2016/679 – concerning Data Subjects X. At the same time, their wide scope (as indicated in the description of Data X and Y) is associated with a high risk of violation of the rights or freedoms of the natural persons affected by the breach. It should be emphasized that, in particular, the unauthorized disclosure of such a category of data as the PESEL identification number (in conjunction with the first name) and may realistically and negatively impact the protection of the rights or freedoms of natural persons. The PESEL identification number, which is an eleven-digit numerical symbol uniquely identifying a natural person, containing among other things the date of birth and gender designation, is therefore closely linked to the private sphere of the natural person and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679. It is data of a special nature and requires such special protection. Furthermore, the inclusion of the national identification number in the context of a personal data breach that has occurred in this case allows for this factor to be treated as aggravating in accordance with Guidelines 04/2022. The fact that the disclosed Data X also included health-related data further increases the risk of infringement of the rights or freedoms of the natural persons to whom this data pertains.

In Guidelines 04/2022, it was indicated: "Regarding the requirement to consider the categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679), Regulation 2016/679 explicitly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 of Regulation 2016/679, as well as data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are involved in the breach or the more sensitive the data, the greater weight the supervisory authority may assign to such a factor. The quantity of data concerning each individual whose data is affected is also

significant, as the scale of the breach of the right to privacy and personal data protection increases with the amount of data concerning each individual.”

4. Any other aggravating or mitigating factors applicable to the circumstances of the case (Article 83(2)(k) of Regulation 2016/679). In considering this factor, it should be noted that the Company was twice summoned to provide explanations within 3 days from the date of delivery of the letter (with the correspondence being received by the Company on November 13, 2023, and January 16, 2024), and it only responded with a letter dated February 19, 2024. Additionally, the President of the UODO requested the Company to present (within 30 days of receiving the request) the annual financial report for the year 2023, and in the absence of this: a statement regarding the total annual turnover for the year 2023 and the annual financial report for the year 2022. This summons was received by the Company on February 14, 2024, but this information was not provided to the supervisory authority by the Company. Therefore, a repeated summons was issued on April 24, 2024, which was delivered on April 29, 2024. The Company's financial report was only presented with a letter dated June 10, 2024.

In determining the amount of the administrative monetary penalty imposed on the Company, the President of the UODO considered the following mitigating circumstances:

1. Actions taken to minimize the harm suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). In this case, based on the collected evidence, the supervisory authority did not find any material damage suffered by the individuals affected by the breach; however, it should be noted that immediately after the disclosure of the personal data breach, even before the initiation of administrative proceedings, the Data Processor took actions that quickly secured the data against further breaches, i.e., against their continued possession by unauthorized persons. As indicated above, the mere breach of data confidentiality also constitutes non-material damage (harm); however, the prompt actions taken to secure the data against being accessed by other unauthorized entities should be assessed as a mitigating circumstance, as in the opinion of the President of the UODO, narrowing the circle of entities that could unlawfully access Data X and Y should be considered as actions taken to minimize the harm suffered by the data subjects.
2. The degree of cooperation with the supervisory authority to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). Before the initiation of proceedings, the Company undertook independent actions aimed at minimizing the risk of similar breaches occurring in the future (changing the data processing procedure).

The fact that the President of the UODO applied sanctions in the form of an administrative monetary penalty against the Company, as well as its amount, was not influenced by other circumstances indicated in Article 83(2) of Regulation 2016/679, namely:

1. The degree of responsibility of the Data Processor, taking into account the technical and organizational measures implemented under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The findings made by the President of the UODO allow for the conclusion that the Data Processor did not fulfill its obligations regarding the implementation of changes in the payroll system, which consequently led to changes being made without conducting ongoing and post-execution checks of the correctness of the actions taken and securing the processed personal data against access by unauthorized persons. The Data Processor bears direct responsibility for violations, and such gross negligence in the processing of personal data, in the case of a professional entity must constitute an aggravating circumstance. However, the fulfillment by the Data Processor of the obligations under Article 32 of Regulation 2016/679 is one of the subjects of this proceeding, and in the circumstances of the considered factual state, the supervisory authority has accepted that it will not treat this condition as an aggravating circumstance (given that the administrative fine imposed in the analyzed case is related to the violation of this specific provision of Regulation 2016/679).
2. Relevant prior violations of the provisions of Regulation 2016/679 (Article 83(2)(e) of Regulation 2016/679) – The President of the UODO did not find any prior violations of data protection regulations committed by the Company, which means there are no grounds for treating this circumstance as

aggravating. And since such a state (compliance with data protection regulations) is a natural state resulting from the legal obligations imposed on the Company, it cannot also have a mitigating effect on the assessment of the violation made by the President of the UODO.

3. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679) – The President of the UODO identified the violation of the provisions as a result of a report of a personal data breach made by X and Y. X and Y, in making this report, were merely fulfilling their legal obligation, and there are no grounds to consider this circumstance as a mitigating factor – especially in the case of the Data Processor. According to the Guidelines on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP 253, “The supervisory authority may become aware of a violation as a result of proceedings, complaints, articles in the press, anonymous tips, or notifications by the data controller. According to the regulation, the controller has the obligation to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor.” Similarly, the EDPB approaches this issue in Guidelines 4/2020, which state that in cases where the controller is subject to specific obligations to report data breaches (e.g., the obligation specified in Article 33 of Regulation 2016/679), the fact of making this report should be considered a neutral circumstance.

4. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679) – Prior to issuing this decision, the President of the UODO did not apply any of the measures mentioned in Article 58(2) of Regulation 2016/679 against the Company in the case under consideration, which means that the Data Processor had no obligation to take any actions related to their application, and such actions, assessed by the President of the UODO, could have had an aggravating or mitigating impact on the assessment of the identified violation.

5. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679) – The Company does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not – as provided by the provisions of Regulation 2016/679 – mandatory for controllers and processors, which means that the circumstance of their non-application cannot be considered against the Data Processor in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Company.

6. Financial benefits obtained directly or indirectly in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679) – The President of the UODO did not find that the Company had obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as aggravating for the Company. The identification of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, the absence of such benefits for the Data Processor, as a natural state independent of the violation and its effects, is a circumstance that, by its nature, cannot be mitigating for it. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits “obtained” – that occurred on the part of the entity committing the violation. The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the administrative fine imposed on the Company, which should be included in the consideration of the condition under Article 83(2)(k) of Regulation 2016/679.

Finally, it is necessary to indicate that in determining the amount of the administrative fine imposed on the Company in this case, the President of the UODO applied the methodology adopted by the EDPB in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of the UODO categorized the violations of the provisions of Regulation 2016/679 identified in this case committed by the Company (see Chapter 4.1 of Guidelines 04/2022). The

Company violated Articles 32(1) and (2) as well as Articles 32(1) and (2) in connection with Article 28(3)(c) and (f) of the Regulation.

2016/679. Violations of these provisions belong - in accordance with Article 83(4)(a) of Regulation 2016/679 - to the category of violations subject to a lower penalty of the two dimensions of penalties provided for in Regulation 2016/679 (with a maximum amount of up to 10,000,000 EUR or up to 2% of the total annual turnover of the enterprise from the previous financial year).

2. The President of the UODO assessed the violations identified in this case as violations of medium severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the following criteria from those listed in Article 83(2) of Regulation 2016/679, which relate to the subject matter of the violations (constituting the "severity" of the violation), were taken into account: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted that considering their cumulative impact on the assessment of the violation identified in this case leads to the conclusion that the level of its severity (understood in accordance with Guidelines 04/2022) is medium. Consequently, the starting amount for calculating the penalty is accepted as being in the range of 10% to 20% of the maximum penalty that can be imposed on the Company, that is - considering the limit set out in Article 83(4) of Regulation 2016/679 - from the amount of 1,000,000 EUR to the amount of 2,000,000 EUR (see Subchapter 4.2.4 of Guidelines 04/2022). The President of the UODO considered the starting amount of (...) EUR (equivalent to (...) PLN) to be appropriate and justified by the circumstances of this case.

3. The President of the UODO adjusted the starting amount corresponding to the medium severity of the identified violation to the turnover of the Company as a measure of its size and economic strength (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises whose annual turnover is less than or equal to 2 million EUR, the supervisory authority may consider making further calculations of the penalty amount based on a value ranging from 0.2% to 0.4% of the starting amount. Given that the Company's turnover in 2023 (ending on December 31, 2023) amounted to (...) PLN, which is approximately (...), - EUR (according to the average EUR exchange rate on January 29, 2024), the President of the UODO deemed it appropriate to adjust the amount subject to calculation to a value corresponding to 0.4% of the starting amount, that is to the amount of (...) EUR (equivalent to (...) PLN).

4. The President of the UODO assessed the impact on the identified violation of the remaining circumstances (besides those taken into account above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate - as assumed by Guidelines 04/2022 - to the subjective side of the violation, that is to the entity itself that committed the violation and to its behavior before the violation, during it, and after its occurrence. A detailed assessment and justification of the impact of each of these criteria on the assessment of the violation have been presented above. The President of the UODO considered that a mitigating circumstance in this case is the action taken by the Company to minimize the damage suffered by the individuals concerned (Article 83(2)(c) of Regulation 2016/679) and the degree of cooperation with the supervisory authority to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679), while an aggravating circumstance was that specified in Article 83(2)(k) of Regulation 2016/679 in the scope indicated in point 4 on page 50 of this decision. The remaining criteria, i.e., from Article 83(2)(d), (e), (h), (i), (j), and (k) (to the extent that they concerned financial benefits gained directly or indirectly by the Company in connection with the violation or losses avoided) of Regulation 2016/679 - as indicated above - did not have any impact, either mitigating or aggravating, on the assessment of the violation and consequently on the penalty amount. Due to the existence of the above mitigating and aggravating circumstances in the case, the President of the UODO deemed it appropriate to further reduce the penalty amount established above, taking into account the Company's turnover (point 3 above); the appropriate reduction in the assessed

cumulative impact of the aforementioned criteria on the assessment of the violation is, in the opinion of the President of the UODO, its reduction to the amount of (...) EUR (equivalent to (...) PLN).

5. The President of the UODO stated that the amount of the administrative monetary penalty determined in the manner presented above does not exceed - in accordance with Article 83(4)(a) of Regulation 2016/679 - the legally defined maximum amount of the penalty provided for the violation (see Chapter 6 of Guidelines 04/2022). As indicated above, the violation of Article 32(1) and (2) and Article 32(1) and (2) in conjunction with Article 28(3)(c) and (f) of Regulation 2016/679 is subject to an administrative monetary penalty of up to 10,000,000 EUR, and in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. The President of the UODO determined that the "dynamic maximum amount" for this violation and for this violator expressed as a percentage (2%) of its turnover would amount to (...) EUR, therefore, in this case, the "static maximum amount" of 10,000,000 EUR should be applied as the higher amount for the violation under consideration. The amount of 5,700 EUR indicated above obviously does not exceed the amount of 10,000,000 EUR.

6. The President of the UODO considered that the amount of the aforementioned penalty does not require additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679, which is one of the three the established circumstances of this case the functions referred to in Article 83(1) of Regulation 2016/679, meaning they are effective, proportional, and deterrent.

It should be emphasized that the penalty will be effective if its imposition leads to the Processor fulfilling its obligations regarding personal data protection in the future. Referring to the amount of the administrative fine imposed on the Company, it should be noted that it does not belong to the group of entities listed in Article 102(1) and (2) of the Act of May 10, 2018, on the Protection of Personal Data (u.o.d.o.), and therefore, in this case, the limitations on the amount (up to 10,000 or 100,000 PLN, respectively) of the administrative fine do not apply. Consequently, pursuant to Article 101 of the u.o.d.o., the administrative fine is imposed on the Company based on and under the conditions specified in Article 83 of Regulation 2016/679.

In the opinion of the President of the UODO, the imposed fine of 24,882.21 PLN (in words: twenty-four thousand eight hundred eighty-two zlotys and twenty-one groszy), which is equivalent to 5,700 EUR (the average euro exchange rate from January 29, 2024 - 4.3653 PLN), meets the criteria mentioned in Article 83(1) of Regulation 2016/679 due to the seriousness of the identified violation in the context of the primary objective of Regulation 2016/679 - the protection of fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data.

Referring to the amount of the imposed administrative fine, the President of the UODO considered it to be deterrent and proportional to the violations that occurred. According to the financial report presented by the Company, the net sales revenue and equivalent for 2023 amounted to (...) PLN, which means that the amount of the administrative fine imposed in this case constitutes approximately (...) % of the aforementioned revenue for the mentioned financial year. At the same time, it is worth emphasizing that the amount of the imposed fine, i.e., 5,700 EUR, is only 0.06% of the maximum amount of the fine that the President of the UODO could impose on the Company for the violations identified in this case - applying, in accordance with Article 83(4) of Regulation 2016/679, the static maximum fine (i.e., 10,000,000 EUR).

In the opinion of the President of the Personal Data Protection Office, the administrative fine will serve a repressive function, as it will be a response to the Processor's violation of the provisions of Regulation 2016/679. It will also serve a preventive function; in the opinion of the President of the UODO, it will indicate to both the Company and other entities the reprehensibility of neglecting their obligations related to the occurrence of a personal data breach.

According to the provisions of Article 103 of the u.o.d.o., the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and

in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year - according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Taking into account all the circumstances discussed above, the President of the Personal Data Protection Office concluded that the imposition of an administrative fine on X, Y, and the Processor is necessary and justified by the weight, nature, and scope of the alleged violations of the provisions of Regulation 2016/679. It should be stated that the application of any other remedial measure provided for in Article 58(2) of Regulation 2016/679, particularly merely issuing a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportional to the identified irregularities in the personal data processing and would not guarantee that the aforementioned entities would not commit similar negligence in the future, as in this case.

In summary, in the opinion of the President of the UODO, all three administrative fines imposed in this case meet the criteria in light of the established circumstances.

the entirety of the individual circumstances of the case
the grounds (penal functions) referred to in Article 83
paragraph 1 of Regulation 2016/679, due to the severity
of the identified violations in the context of the fundamental
requirements and principles of Regulation 2016/679.

Having taken the above into account, the President of the Office for Personal Data Protection has decided as stated in the operative part of this decision.

[1] B. Adamiak, [in] B. Adamiak, J. Borkowski, Administrative Procedure Code. Commentary, Warsaw 2004, p. 371.

At the same time, the penalty of 20,000 PLN imposed on
Y for the violation of all the above provisions – in accordance with Article 83 paragraph
3 of Regulation 2016/679 – does not exceed the amount
of the penalty for the most serious violation identified in this
case, namely the violation of Article 5 paragraph 1 letter
f) and Article 5 paragraph 2 of Regulation 2016/679, which
in accordance with Article 83 paragraph 5 letter a) of Regulation
2016/679 is subject to an administrative monetary penalty
of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total
annual worldwide turnover from the previous financial year, nor does it exceed the penalty limits
specified
in Article 102 paragraph 1 point 1 of the Act on the Protection of Personal Data.

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2024-10-10

Information entered by:

Wioletta Golańska

2024-11-04 15:22:58

Last modified by:

Agnieszka Kaczor

2024-11-05 11:29:12